

# Breaking Wi-Fi Easy Connect

## A security Analysis of DPP

George Chatzisoifroniou (@\_sophron)



# DEF CON 33

August 7-10, 2025 | Las Vegas

Presented research has also been peer-reviewed and published in:

Chatzisoifroniou, G., Kotzanikolaou, P. Security analysis of the Wi-Fi Easy Connect. *Int. J. Inf. Secur.* 24, 74 (2025). <https://doi.org/10.1007/s10207-025-00988-3>

# whoami

- Performed infrastructure and application security assessments for Fortune 500 companies across Africa, Asia, Europe, and North America
- Over a decade of research focused on Wi-Fi security and protocol analysis
- Published novel association techniques (e.g., Known Beacons, Lure10)
- Author of wifiphisher, an open-source framework combining Wi-Fi attacks with phishing strategies

# Wi-Fi Easy Connect

- Released by the Wi-Fi Alliance in 2018 as a companion to WPA3
- Designed as a secure and user-friendly replacement for WPS
- Supports the growing demand for IoT device onboarding with minimal user interaction
- Supports multiple bootstrapping methods: QR codes, NFC, BLE, PKEX
- Addresses security flaws in WPS (e.g., offline PIN brute-force attacks)
- Based on Device Provisioning Protocol (DPP)
- Uses public key cryptography for authentication and secure provisioning between devices.
- Certification is limited, but adoption is rising: ~32 certified devices across 12 vendors (as of July 2025).
- Primarily used in Android (10+) as Initiator only — cannot act as Configurator/Responder.

# Roles in WiFi Easy Connect

## STA - AP

- **STA (Station):** The client device — phone, laptop, toaster — that connects to a Wi-Fi network by associating with an AP.
- **AP (Access Point):** The network's gatekeeper.
- STA joins the BSS managed by the AP

## Initiator - Responder

- **Initiator:** Entity that starts DPP authentication.
- **Responder:** Entity that answers initiation of the DPP authentication.
- Example: Phone (Initiator) provisioning a smart plug (Responder).

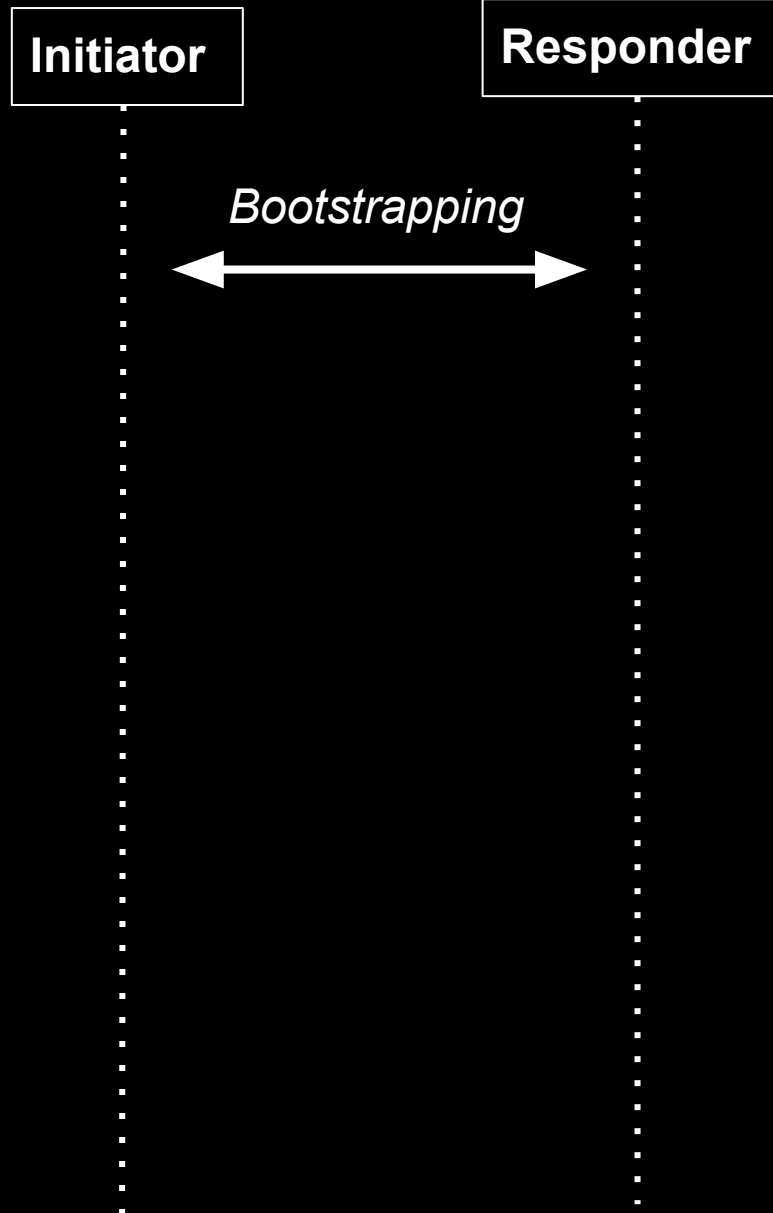
## Configurator - Enrollee

- **Configurator:** Trusted device that provisions network credentials.
- **Enrollee:** Device being provisioned to join the network.
- Configurator acts as “the gatekeeper” issuing credentials securely.

# Phases of Wi-Fi Easy Connect

## 1. Bootstrapping

- Initial step to establish trust.
- Uses QR code, NFC, BLE, or PKEX for device discovery and public key exchange.



# Phases of Wi-Fi Easy Connect

## 1. Bootstrapping

- Initial step to establish trust.
- Uses QR code, NFC, BLE, or PKEX for device discovery and public key exchange.
- Successful bootstrapping = both sides exchange and store each other's public keys
- public bootstrapping keys = credentials!

*Receives  
Responder's Public  
Bootstrapping Key*

Initiator

*Bootstrapping*

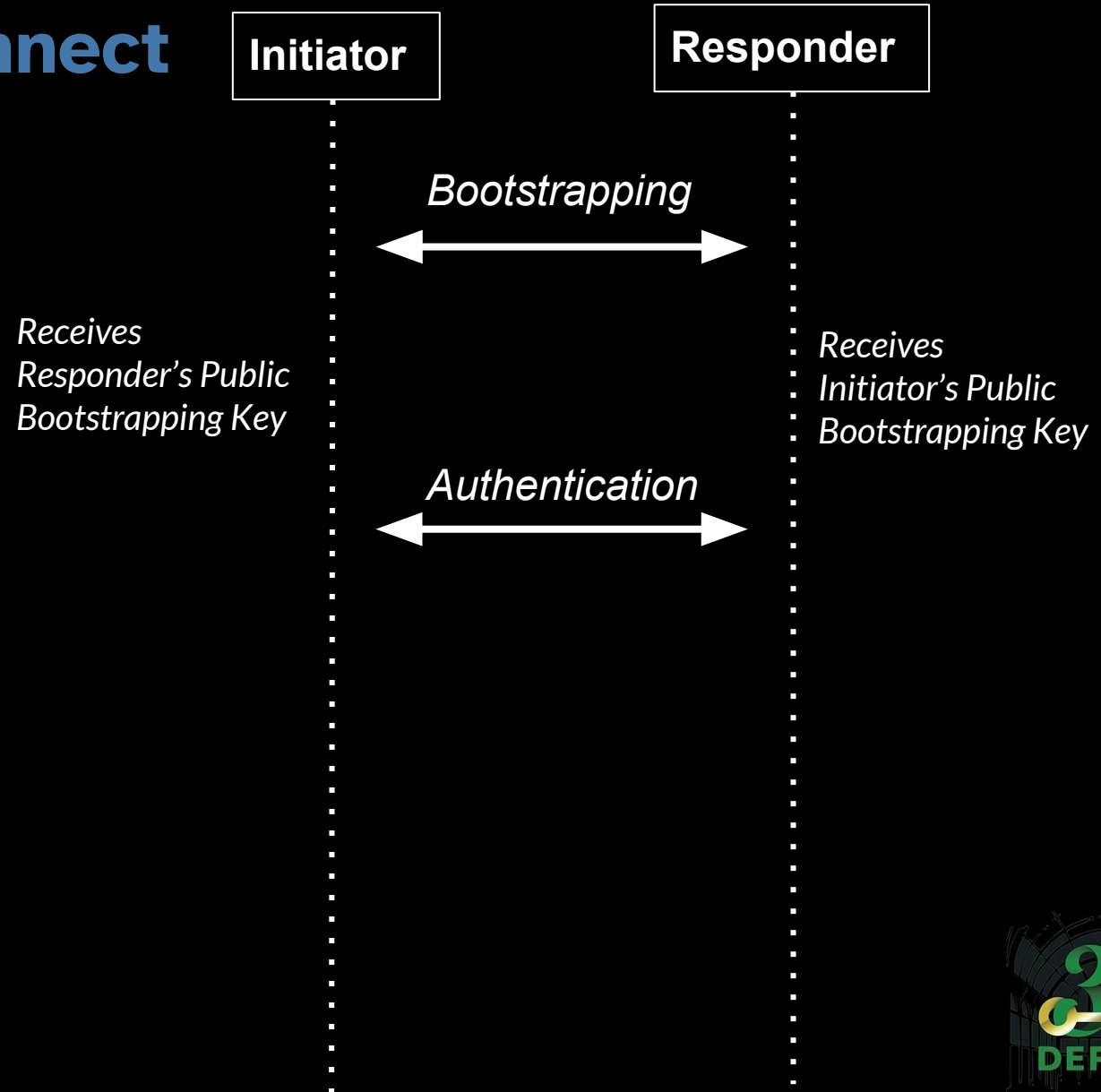
Responder

*Receives  
Initiator's Public  
Bootstrapping Key*

# Phases of Wi-Fi Easy Connect

## 2. Authentication

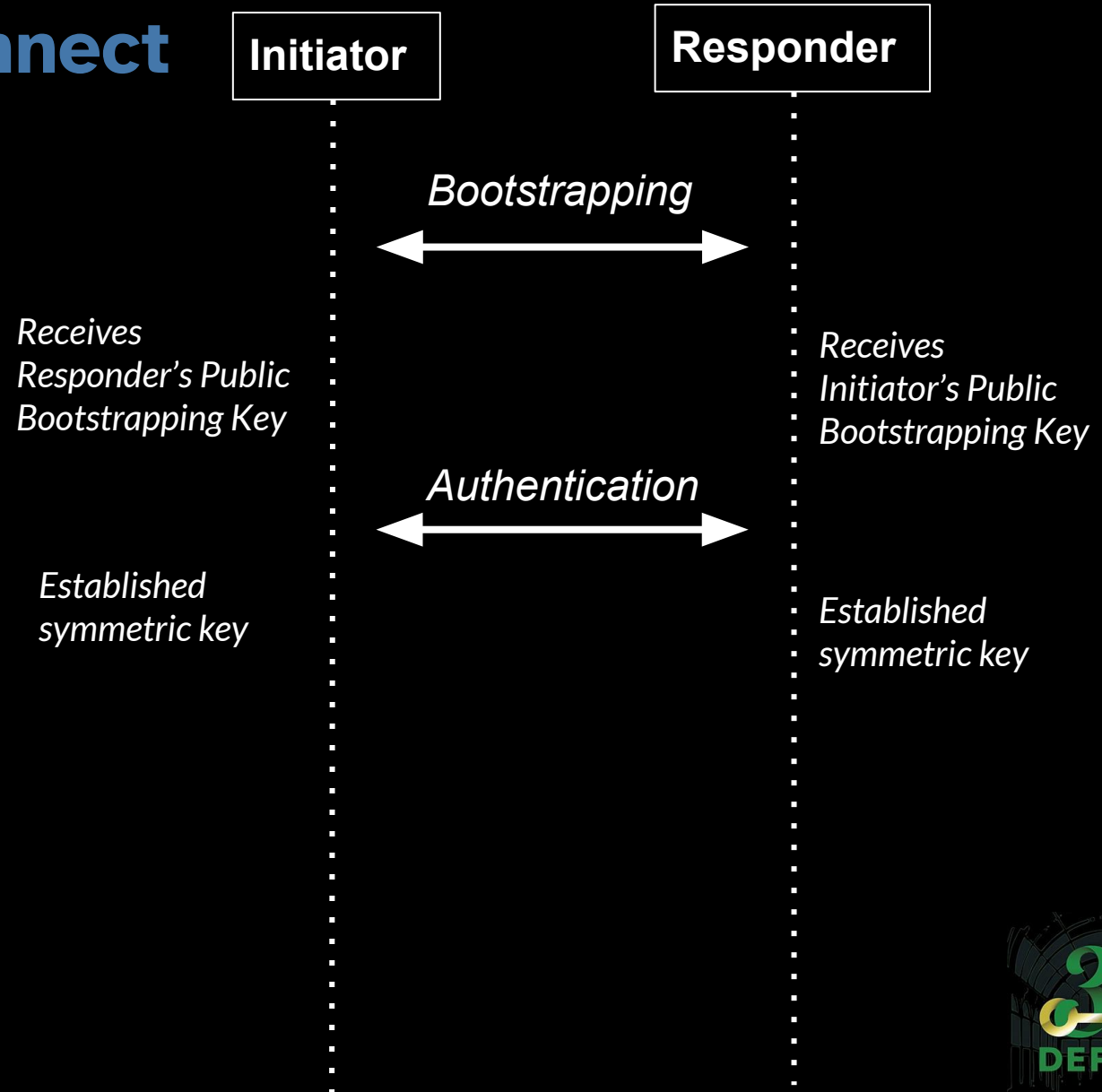
- Leverages exchanged public keys to perform mutual authentication and key agreement.



# Phases of Wi-Fi Easy Connect

## 2. Authentication

- Leverages exchanged public keys to perform mutual authentication and key agreement.
- Successful authentication = both sides derive the same symmetric key

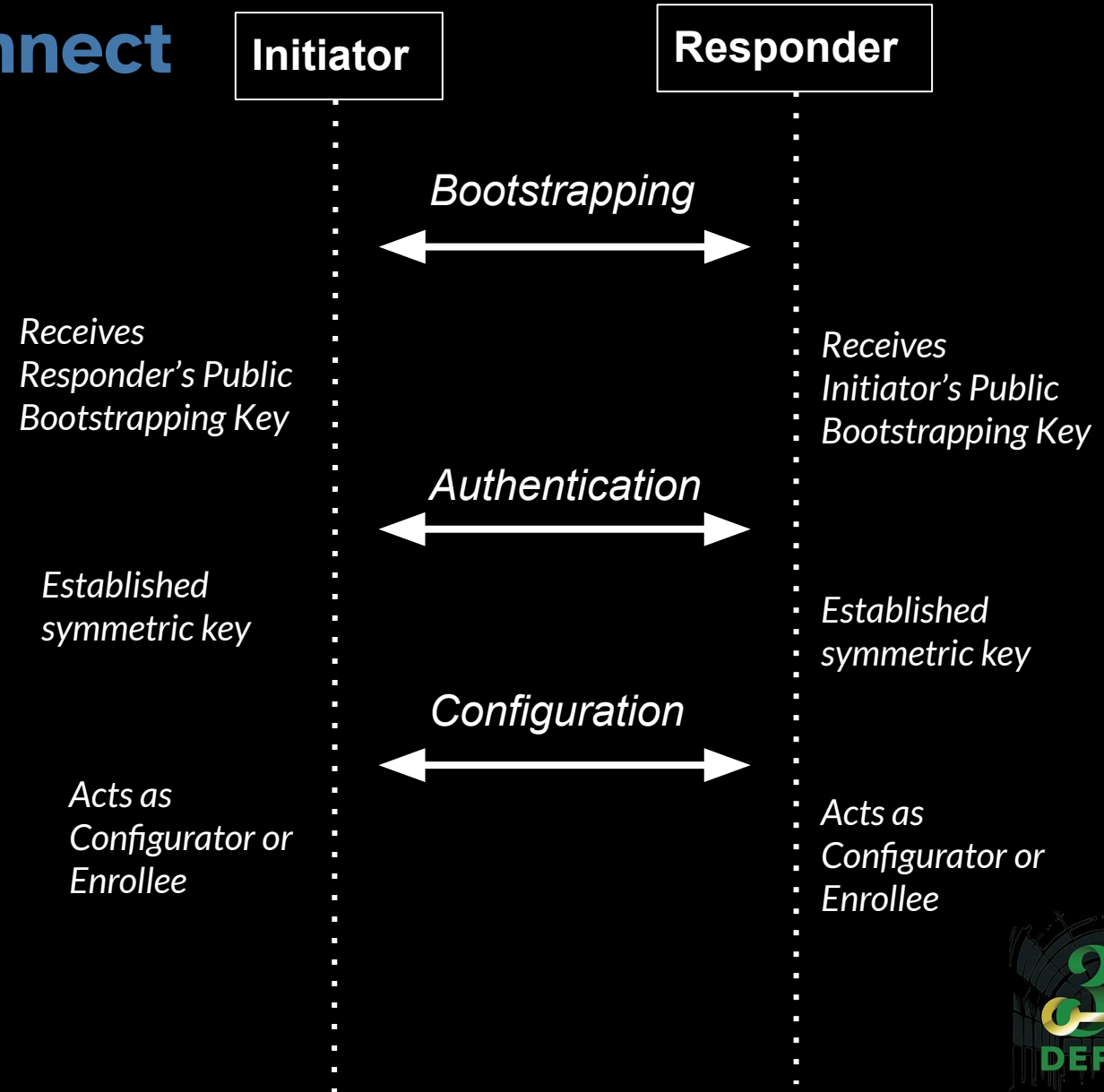




# Phases of Wi-Fi Easy Connect

## 3. Configuration

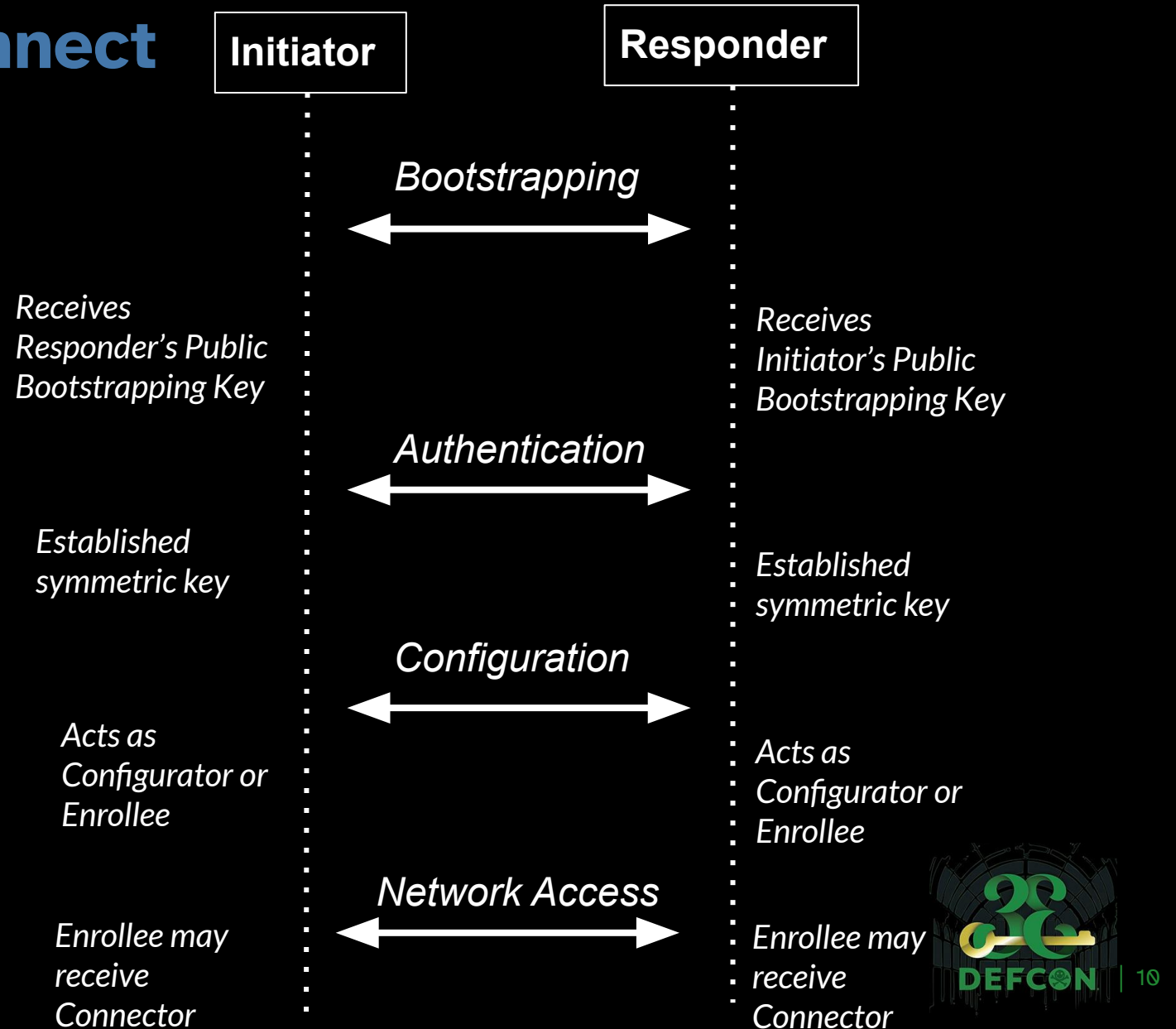
- Establish actual communication keys, known as the connector keys (Connector-I and Connector-R respectively).



# Phases of Wi-Fi Easy Connect

## 4. Network Access

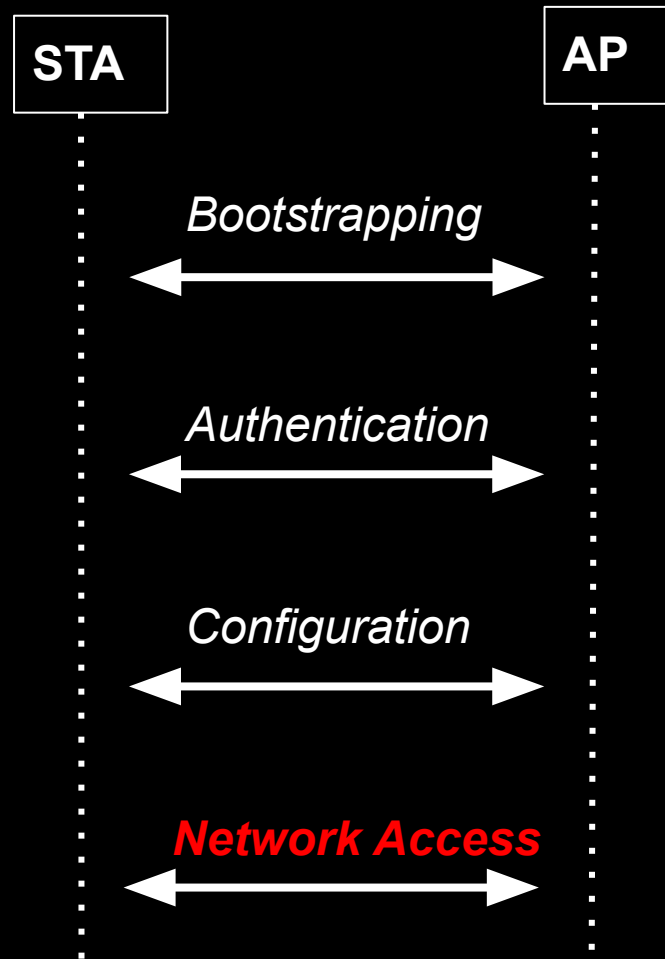
- Enrollee uses provisioned credentials to connect to the Wi-Fi network.
- Operates under WPA2 or WPA3 for subsequent data communication.



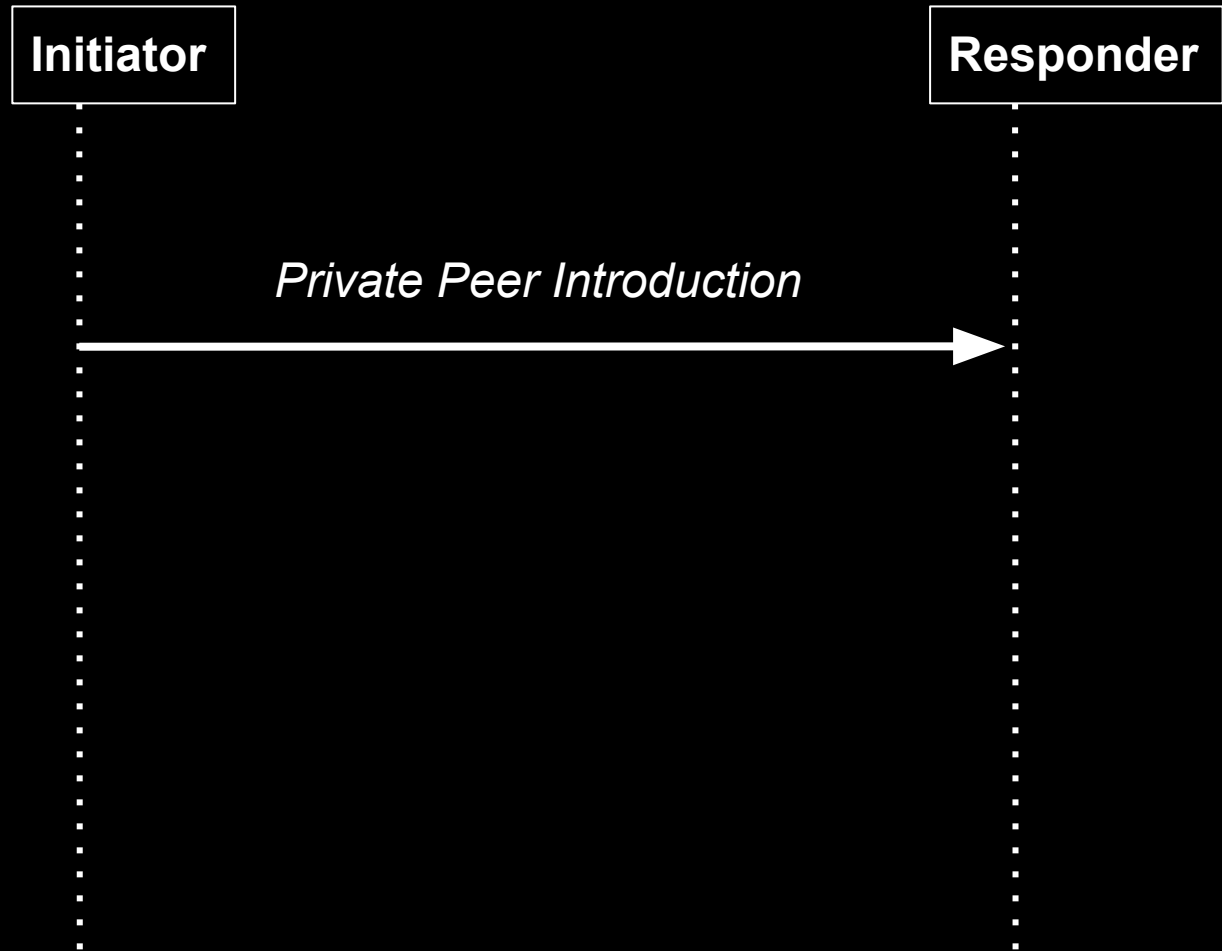


# Recon

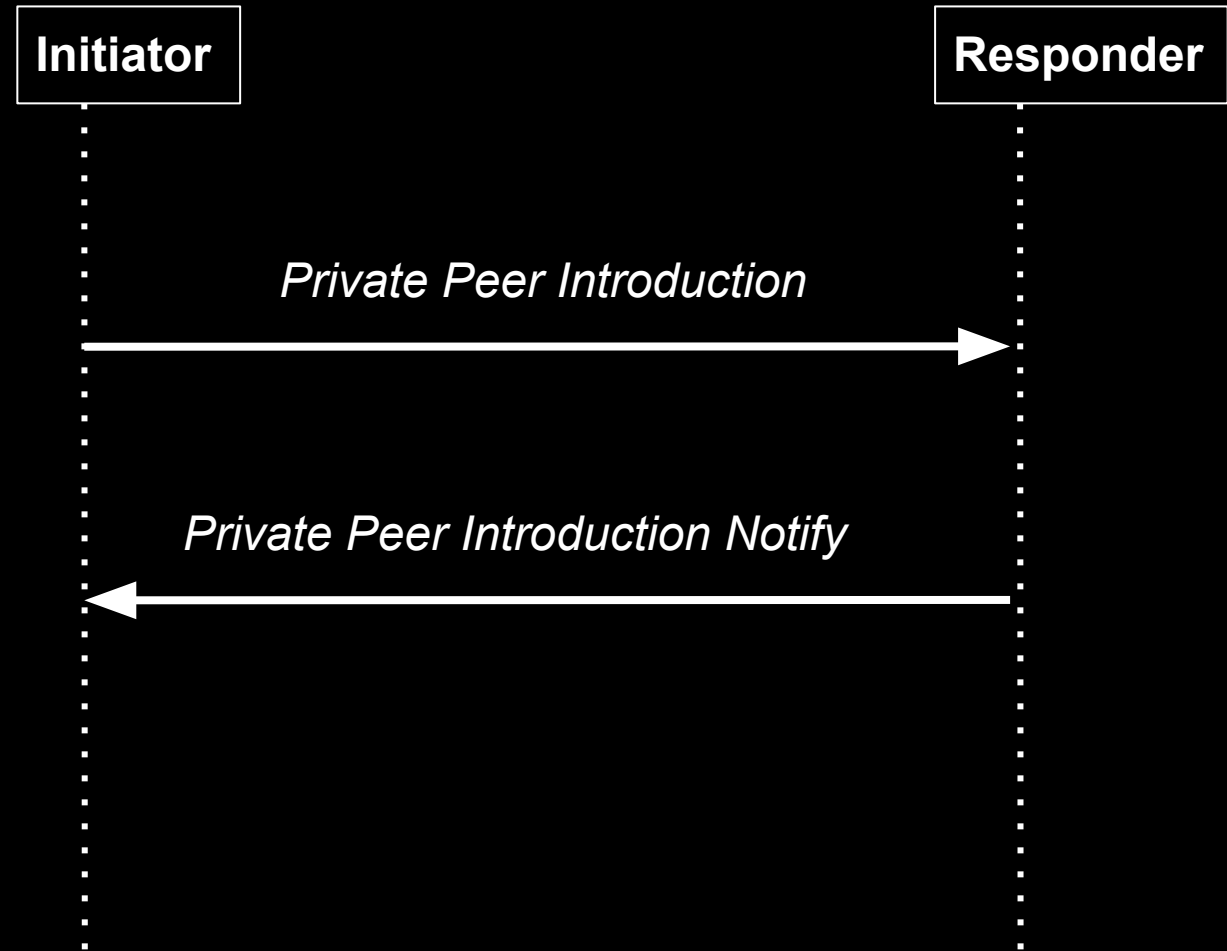
- Discover active Wi-Fi Easy Connect (DPP) networks and connected clients
- **Method 1:** Sniff Beacon frames or Probe Responses advertising DPP AKM
- **Method 2:** Force downgrade on Enrollees attempting private introduction



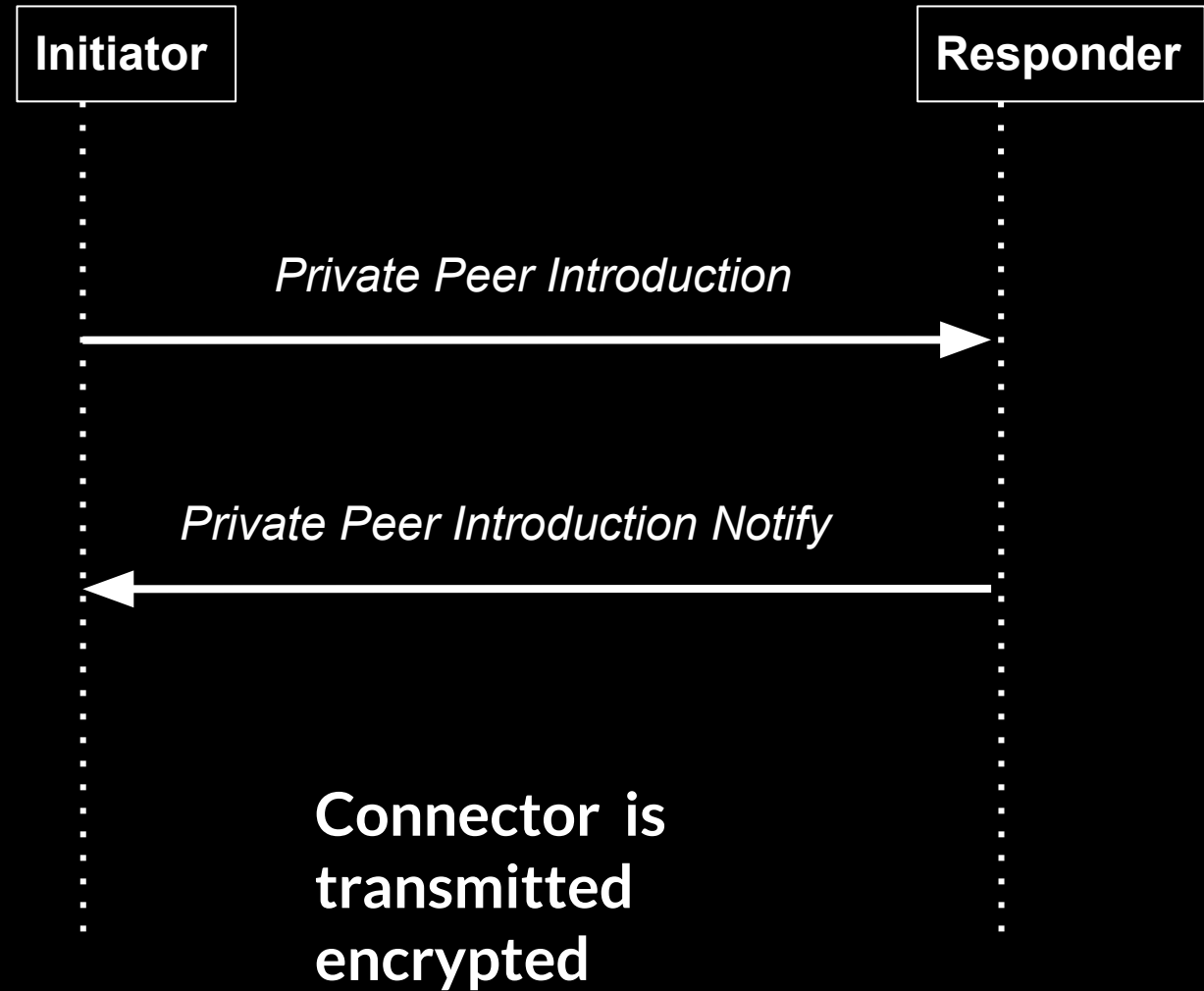
# Private Introduction Protocol



# Private Introduction Protocol

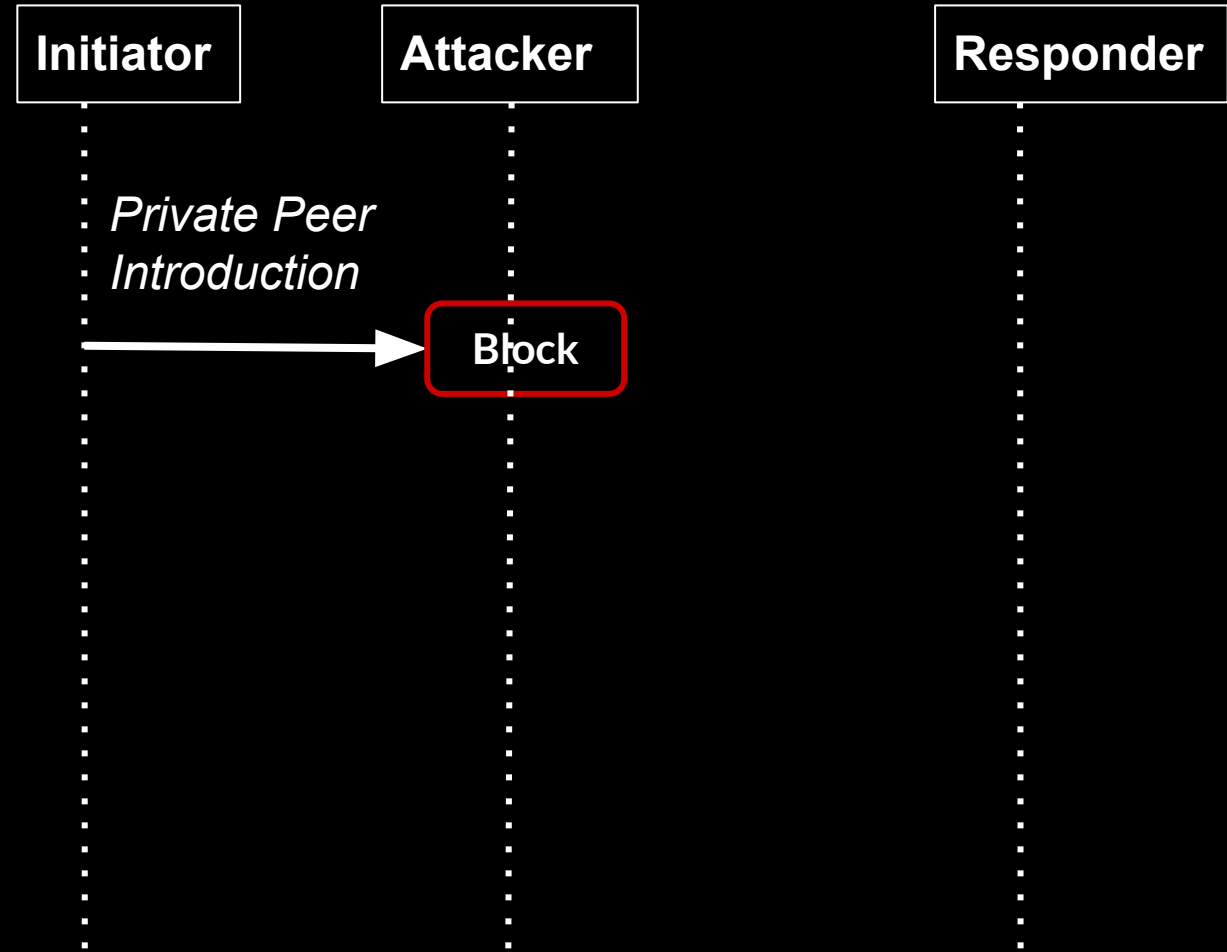


## Private Protocol Downgrade

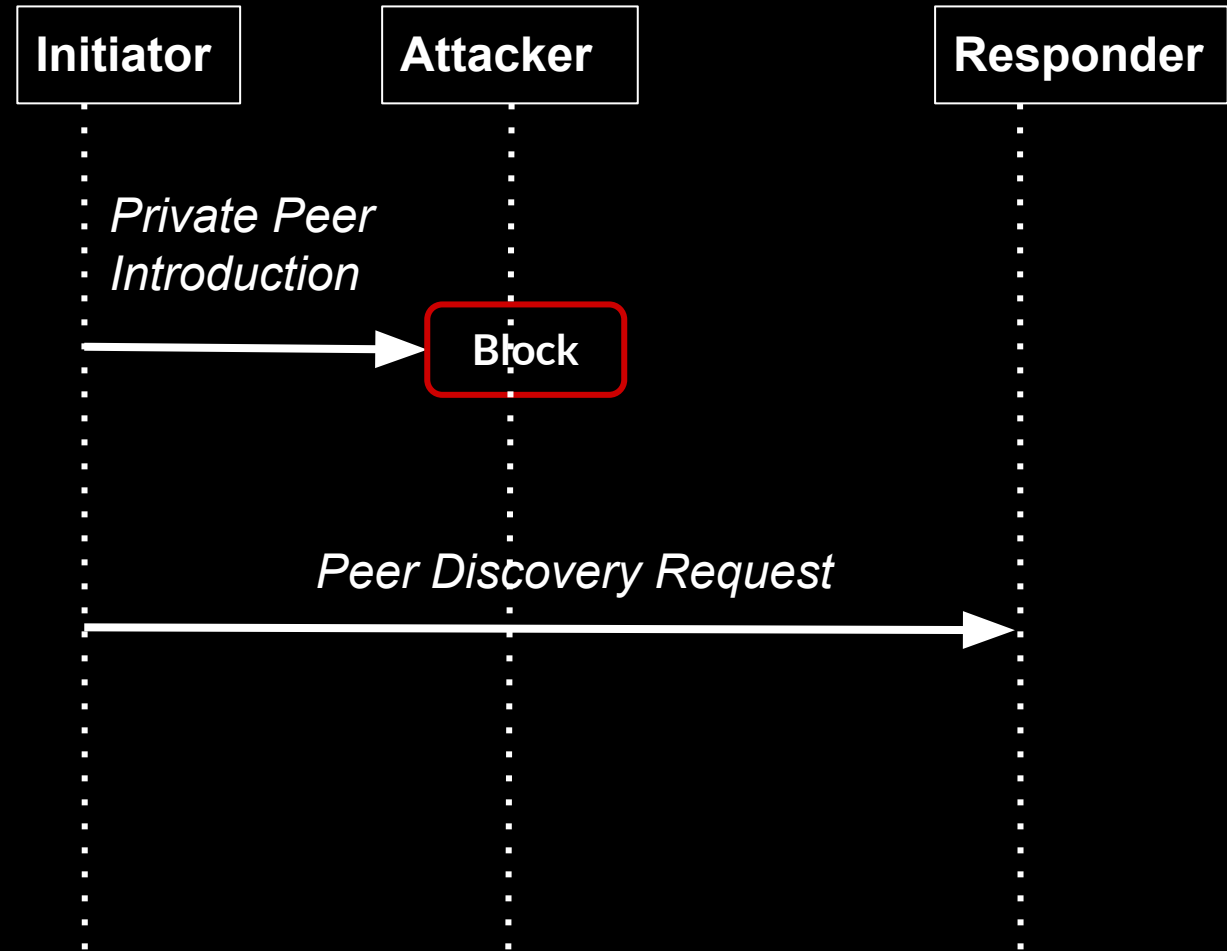




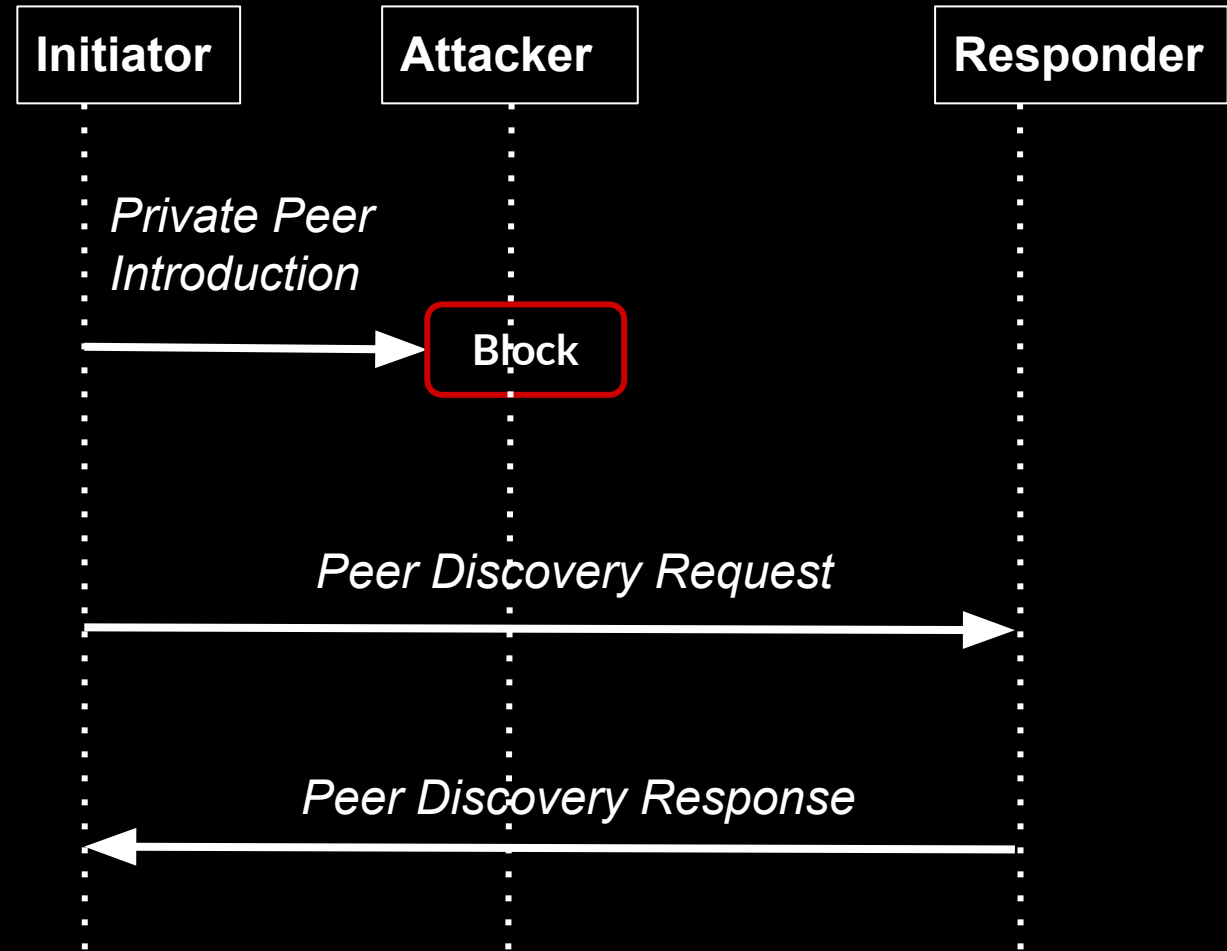
# Private Protocol Downgrade



# Private Protocol Downgrade



# Private Protocol Downgrade







```
{
  "wi-fi_tech": "infra",
  "discovery": {
    "ssid": "wakeupneo"
  },
  "cred": {
    "akm": "dot1x",
    "entCreds": {
      "certBag": {
        "MIIFCwYJKoZIhvcNAQcCoIIE/DCCBPgCAQExADALBgqhkiG9w0BBwGgggTeMIICJDCCAaqgAwIBAgIU0BgMq1Hjyof9rrj5A08
+ZmB4jw/UwCgYIKoZIzj0EAwMwaTElMAkGA1UEBhMCVVMxCzAJBgNVBAGTAkNBMRcwFQYDVQQHEw5MYSBTZWx2Y5B6ZWFjaDEeM
BwGA1UEChMVVGhlIEluZHVzdHJpYWwgTG91bmdlMRQwEgYDVQQDEwtUaGUgQm91bmNlcjAeFw0yMDA1MjAxNjAyMDlaFw02MDA1
MTgxNjAyMDlaMGkxCzAJBgNVBAYTA1VTMQswCQYDVQQIEwJDTExMBGUGA1UEBxMOTGEGU2VsdmEgQmVhY2gxHjAcBgNVBAoTFVkr
oZSBjb2R1c3RyaWFsIExvdW5nZTEUMBIGA1UEAxMLVGhlIEJvdW5jZXIwdjAQBgcqhkiG9w0BBwUgQm91bmNlcjAeFw0yMDA1
22r2LjIjRcB6pTd4K+H0+tp6U/PS/hcL1ybbQXruF0ba8d+rru9ncUm44jK9nuxmkb0w9eypN18l1SdBYet7iR+BtFh2sFhh0UuE
jQsXEDp2QHd1Qlgyf0jEzARMA8GA1UdEwEB/wQFMAMBAf8wCgYIKoZIzj0EAwMDaAAwZQIXAIkhly68Muhbuj0/IeOTGb60vuot
QG/s8VaoPrKHQ6FJuJNP0c9tojtAzpIwiPRKvwIwSYs9kxEgRaC4Zb0jywiXM8CIbdG08B8gU6+hyNf3KZZAnXRKmTL3Tg95rj5
ZLYnmMIICsjCCAjegAwIBAgIBfTAKBggqhkiG9w0BBwUgQm91bmNlcjAeFw0yMDA1MjAxNjAyMDlaFw02MDA1MTgxNjAyMDla
NlBhZzhIEJlYWNoMR4wHAYDVQQKEwVUaGUgSW5kdXN0cm1hbCBMb3VuZ2UxZDASBgNVBAMTC1RoZSBjb2R1c3RyaWFsIEJvdW5n
TIyNTc10FoXDTMwMDYyMzIyNTc10FowDzENMA5GA1UEAwEYm94eTB2MBAGByqGSM49AgEGBSuBBAAiA2IABNb1skZ46EYfPMW9
Mb44Xz3T0LeGNuVu0ZqbDzv/vK0/jCE46EcuN9Q6XMY7w/mShJPWs7q3gjyvbNzAaQjNB/8LBEz9fJhf7K4vfXEDxmzMKoKCxCF
PVTp1DwbdEMmh+a0CAQswggEHMAkGA1UdEwQCMAAwCwYDVR0PBAQDAgWgMBMGA1UdJQQMMAoGCCsGAQUFBwMCMB0GA1UdDgQWBB
TkFhA73mfYSB5SVcwFAxEn7JXkGTcBkAYDVR0jBIGIMIGFoW2kazBpMQswCQYDVQQGEwJVUzELMAkGA1UECBMCQ0ExFzAVBgNVB
AcTDkxhIFNlbHZhIEJlYWNoMR4wHAYDVQQKEwVUaGUgSW5kdXN0cm1hbCBMb3VuZ2UxZDASBgNVBAMTC1RoZSBjb2R1c3RyaWFs
AygUePKh/2uuPkdTz5mYHiPD9TASBgNVBAUEC1NNRVJTS03NDc0MBIGCgmsJomT8ixkAQUEBGJlZXIwCgYIKoZIzj0EAwMDaQA
wZgIXAMydhqh9flMPX9MPRs/l/Hio1gG93Q16lKa0rWYtVCh/okQgvLIftTng5JtPnx75gIXAN0iutLLRtQcEVhaoJhQzXPsmc
XAuczDdUvWo670tTzhx5dFu+SBSYLXpBbagf05/aEAMQA="},
    "signedConnector": "eyJ0eXAiOiJkcHBDb24iLCJraWQiOiI5e1lRN1U0a1VBcXhHcGlJcGlPNGdDNUVER2pxM1JKSHZRcElW
TzB1WEpjIiwiaW50dQifQ.eyJncm91cHMl0lt7Imdyb3VwSWQiOiJpbm91bm9sZSI6ImFwIn1dLCJu
ZXRBY2Nlc3NLZXkiOiJ0nsia3R5IjoIRUMiLCJjcniYiOiJQLTI1NiIsIng1OiJfOUdzN3FrOUNsODd1dVZia3Y1Xz1UUnhkX0lNSE9
tUEFWazNPUl85T1VrIiwieSI6I1ZR5zd0c1ZkUf8wU3Q5UGdZT2ZLWEY0MzctdlB0QkRQcXp0aXl3RTVpbW8iLCJraWQiOiJHT1
lKSkd3ZGdjOXdwVR6VFI0eERkQWNGeTQxOGkyTXBCYXFUV0Mty1dvIn0sImV4cGlyeSI6IjIwMjEtMDUtMjVUMjI6NTY2MjI1f
Q.f20aXqprq82QZ9qEc-UwMiI8bVU0ldSedD4T8n8ZcTKXgQYf1lQpB8yyKsM9CGXhkDXtL46GKH5xuXfU1V0Q0fRa5BeQST
SM-g3MFKNeMU3mhdPCpUXFt9B3Y6p6jm3",
    "csign": {
      "kty": "EC",
      "crv": "P-384",
      "x": "K9M0-qd__Y69e5Pdn7Rs7E_bwWP04i9GDUE0EB9rdTRT3gIAK8Q7XL-Kqp1ibrUn",
      "y": "9ME5C4DM7CkEDNK8R0YEYx92bxqxZV46qtSjTZUsmM89pS-FPXuYxuioR5uW9GXE",
      "kid": "9zYQ7U4kUAqxGpiIpi04gC5EDGjq3RJHvQpIV00uXJc",
      "expiry": "2021-05-25T22:56:22"
    }
  }
}
```

SSID



# Wi-Fi Alliance Response

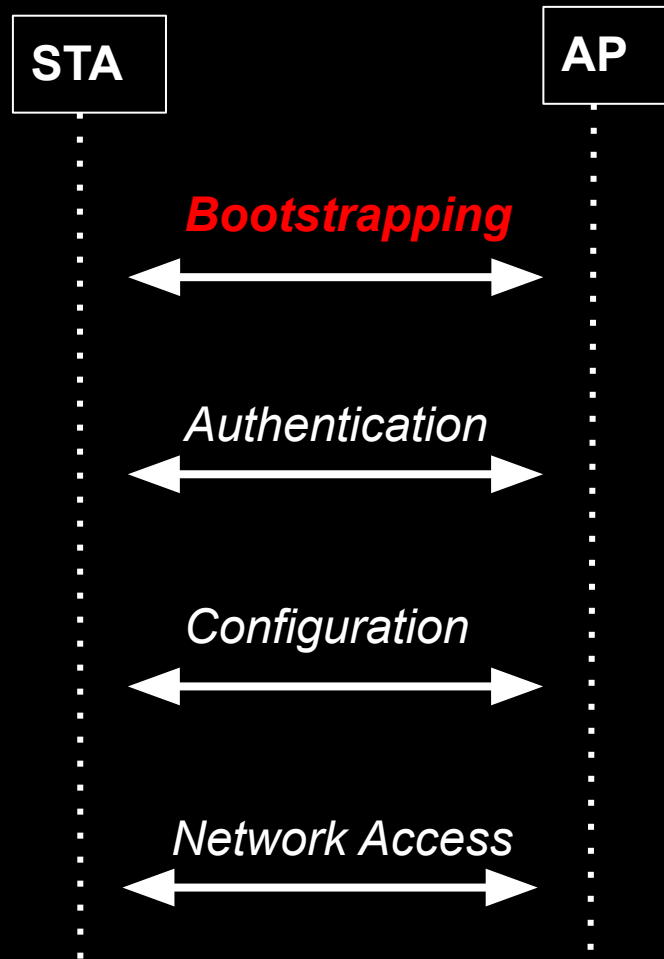
“Wi-Fi Alliance considers the attack an acceptable risk. Inducing the abandonment of the Private Introduction Protocol and forcing the use of Network Introduction Protocol is merely privacy-exposing as it will expose the non-AP STA’s connector to a passive attacker.”

# Proposed Remediation

- Future DPP specifications should validate STA preferences from the AP during subsequent exchanges
- Ensure ongoing verification of the STA's intent and configuration parameters throughout the session







# Wi-Fi Provisioning Method: PKEX

- Public Key Exchange (PKEX) protocol
- Password-authenticated key exchange within Wi-Fi Easy Connect
- Relies on shared secrets (like a short numeric code)
- Elliptic Curve Diffie-Hellman (ECDH)

## Group Selection in PKEX (Initiator $\longleftrightarrow$ Responder)

- Initiator proposes a cryptographic group (e.g., ECC curve) in the initial message
- Responder either:
  - Accepts the group (proceeds with same group)
  - Or downgrades to a different group if it doesn't support the proposed one

## PKEX Group Exchange

Groups Ordered by Preference

Initiator: 26, 30, 29, 27

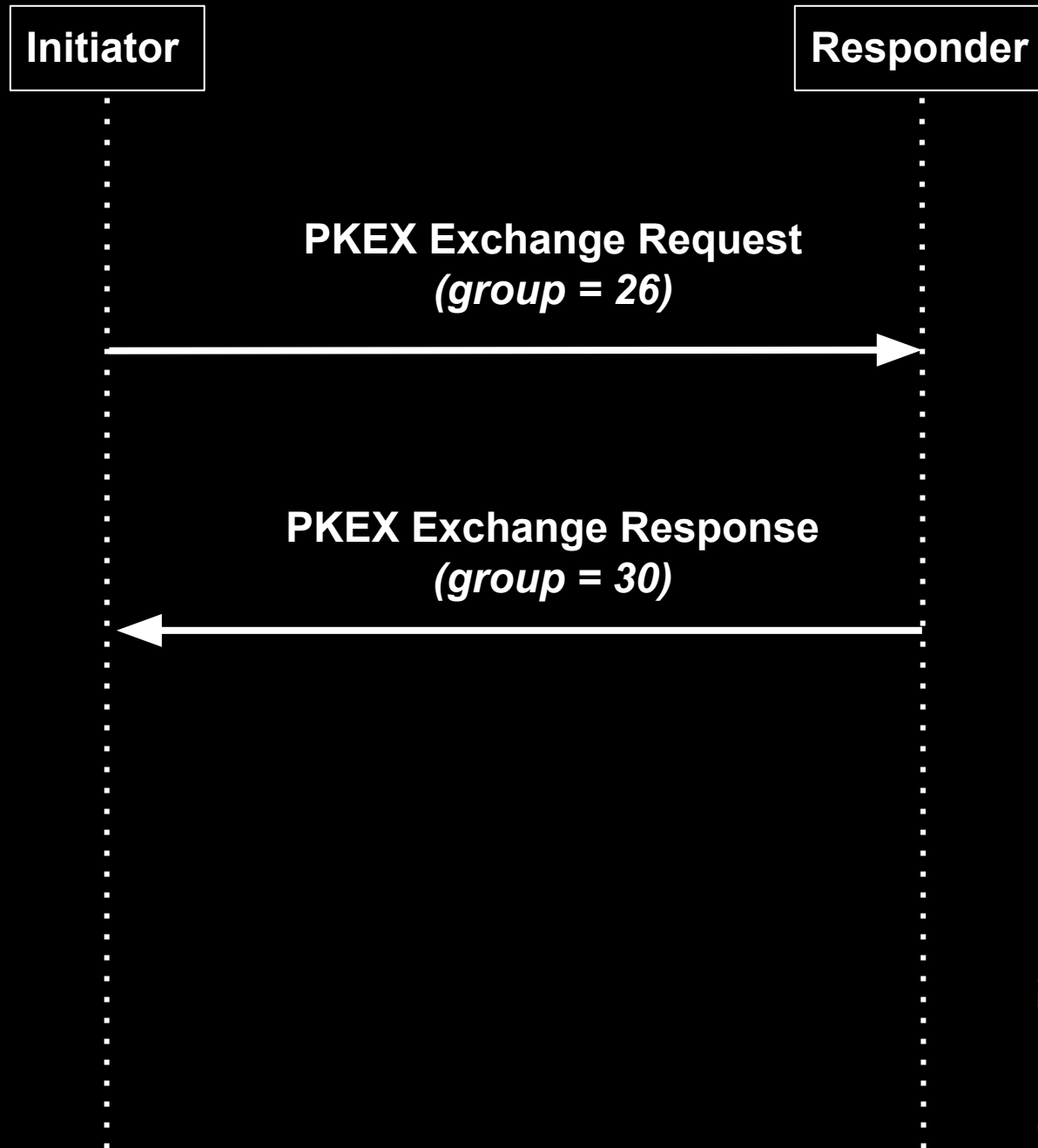
Responder: 30, 29, 28, 27



## PKEX Group Exchange

Groups Ordered by Preference

Initiator: 26, 30, 29, 27  
Responder: 30, 29, 28, 27

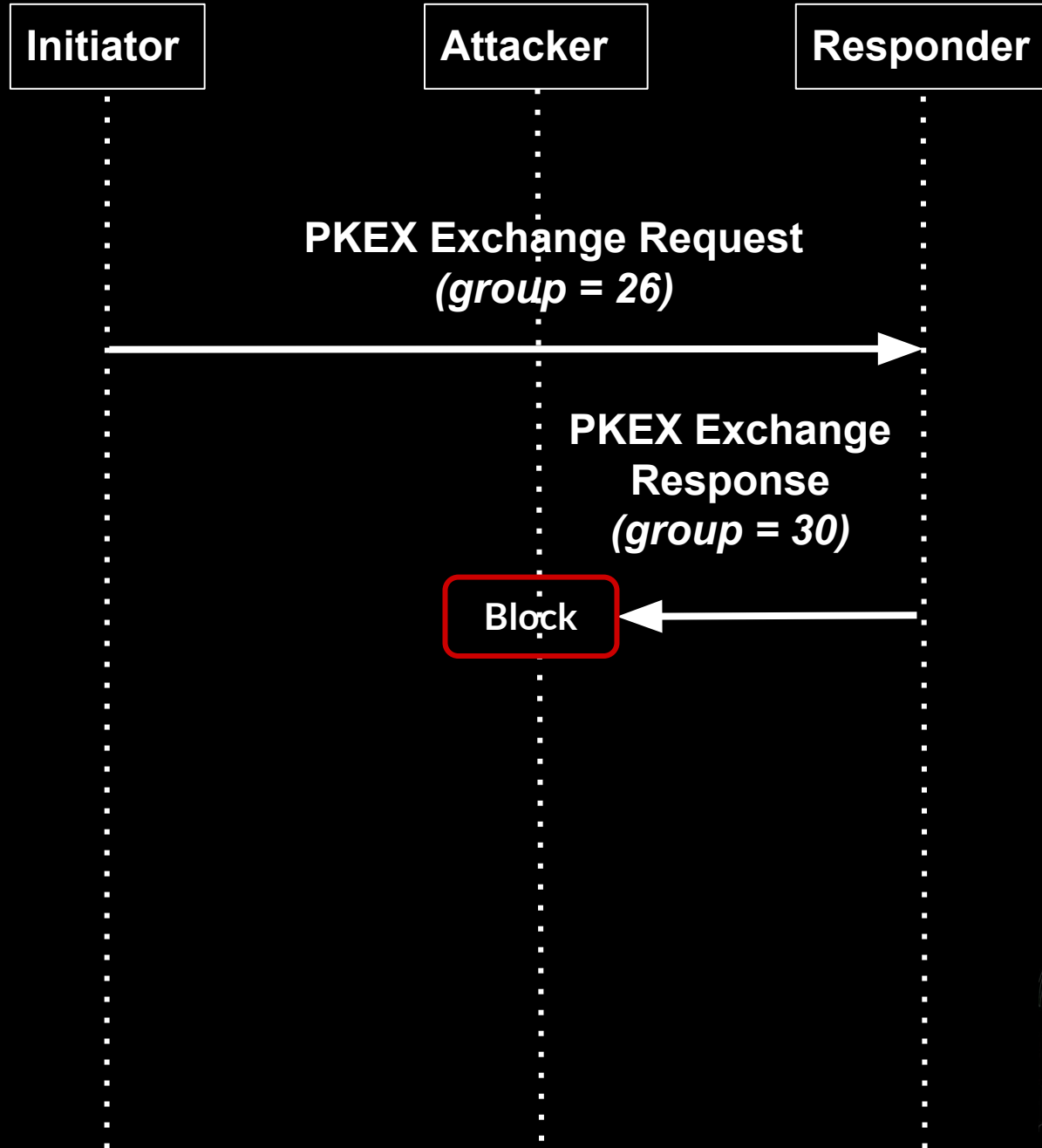


# PKEX Group Downgrade Attack

Groups Ordered by Preference

Initiator: 26, 30, 29, 27

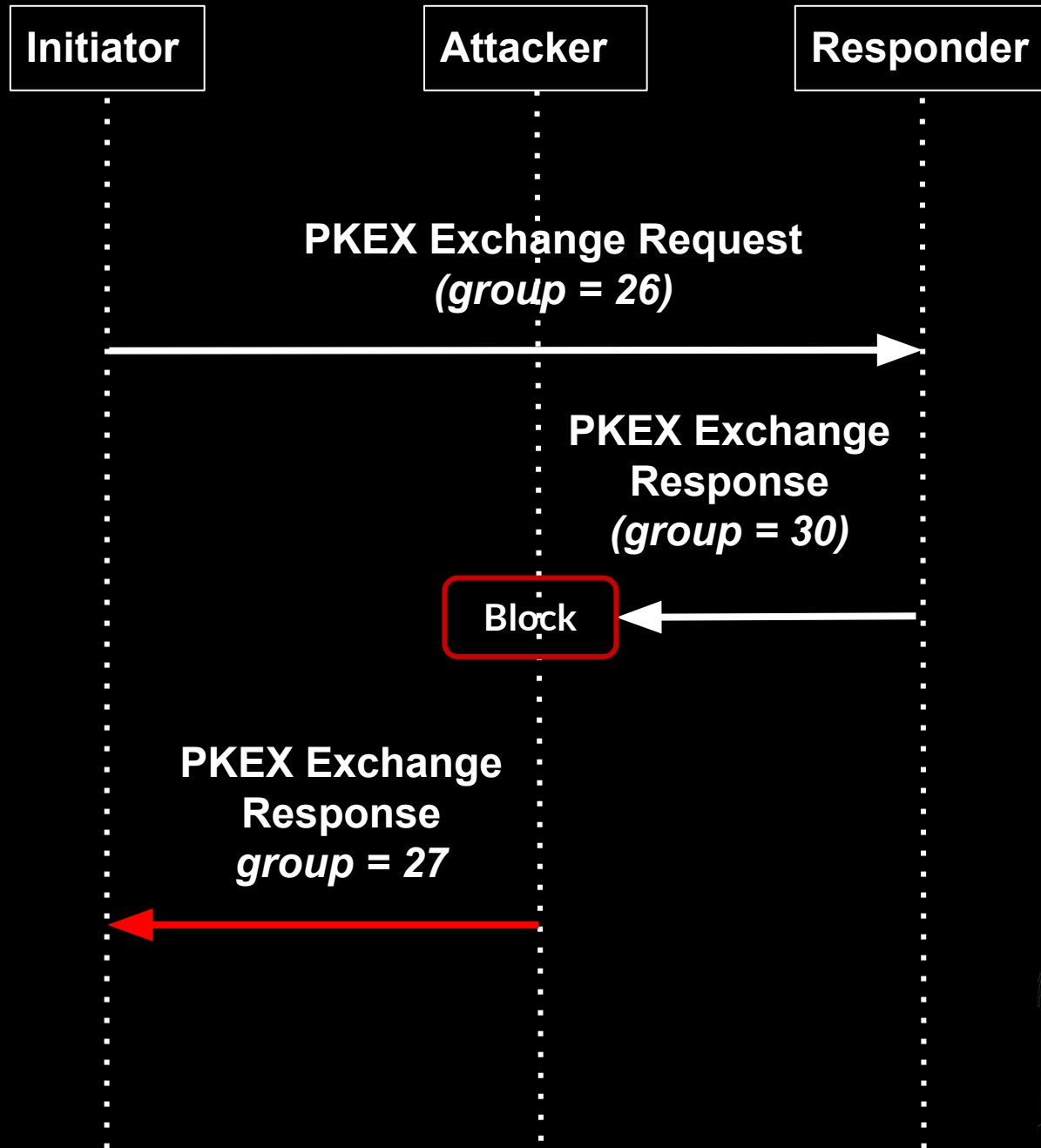
Responder: 30, 29, 28, 27



# PKEX Group Downgrade Attack

Groups Ordered by Preference

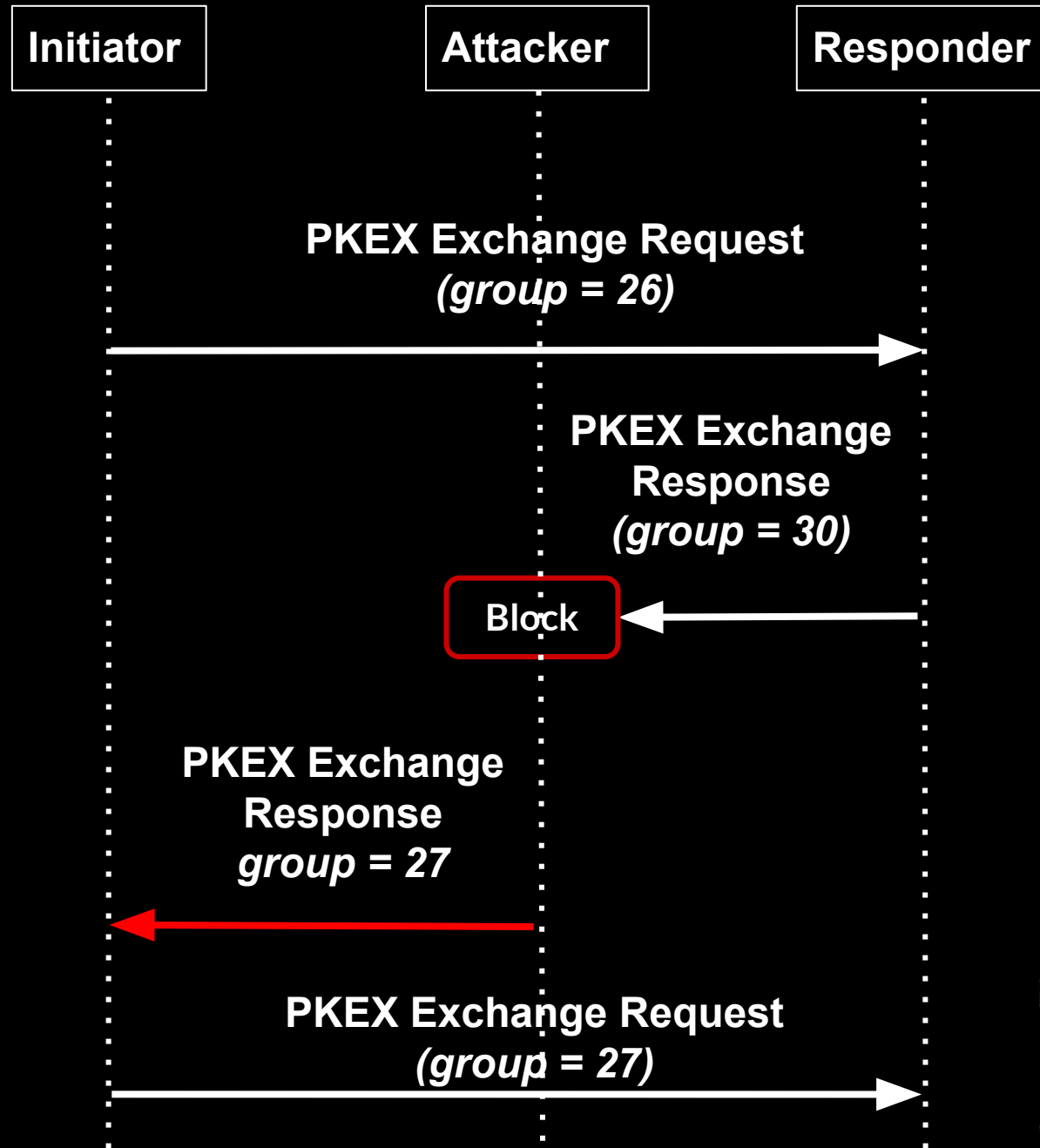
Initiator: 26, 30, 29, 27  
Responder: 30, 29, 28, 27



# PKEX Group Downgrade Attack

Groups Ordered by Preference

Initiator: 26, 30, 29, 27  
Responder: 30, 29, 28, 27





# PKEX Group Downgrade Attack

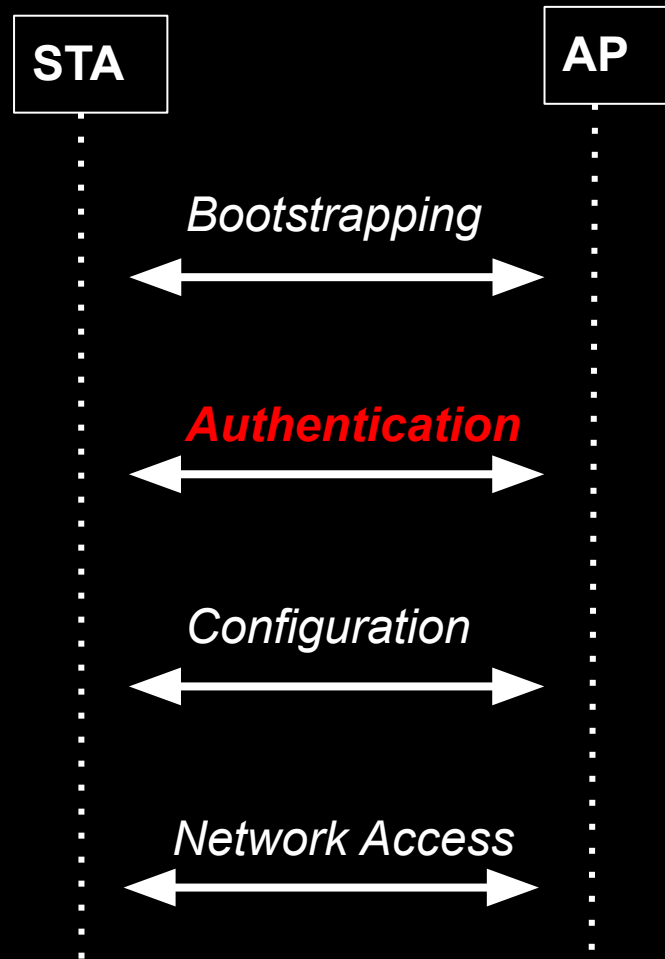
- DPP's group negotiation lacks cryptographic safeguards present in WPA3's SAE (802.11) group negotiation.
- Weak group selection = weaker DH exchange = easier brute-force
- Some curves, like certain NIST P-curves, are avoided due to opaque parameter generation and potential backdoor concerns
- Exploitation is uncommon in typical environments due to practical constraints

# Wi-Fi Alliance Response

“Wi-Fi Alliance will take this matter under discussion and decide a course of action regarding cryptographic protection of group negotiation.”

# Proposed Remediation

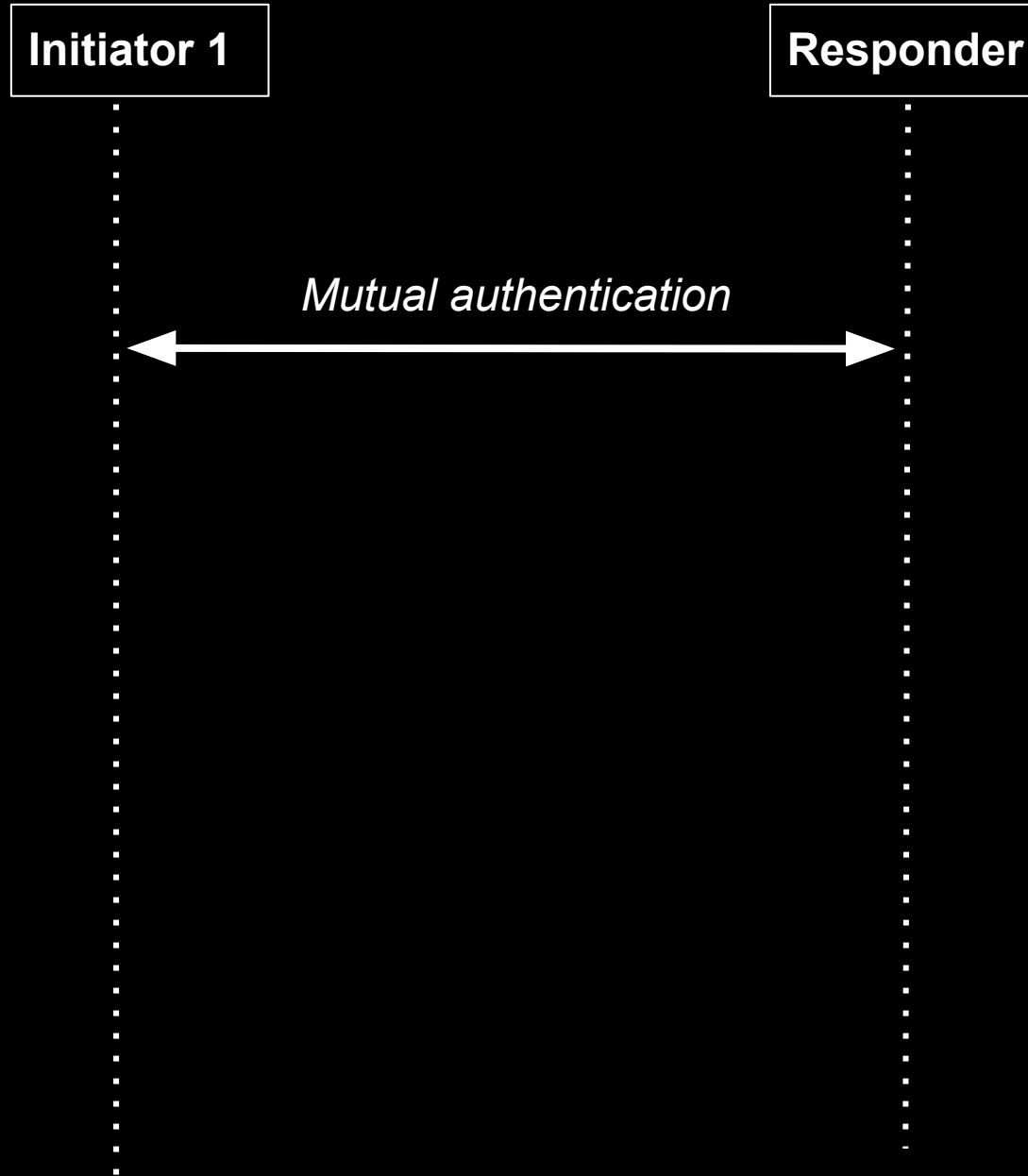
- Responder includes supported groups in the signed commitment during the Commit-Reveal phase
- If the commitment from Responder  $\neq$  locally computed version  $\longrightarrow$  tampering detected, likely downgrade attempt
- Initiator aborts the protocol if mismatch is found



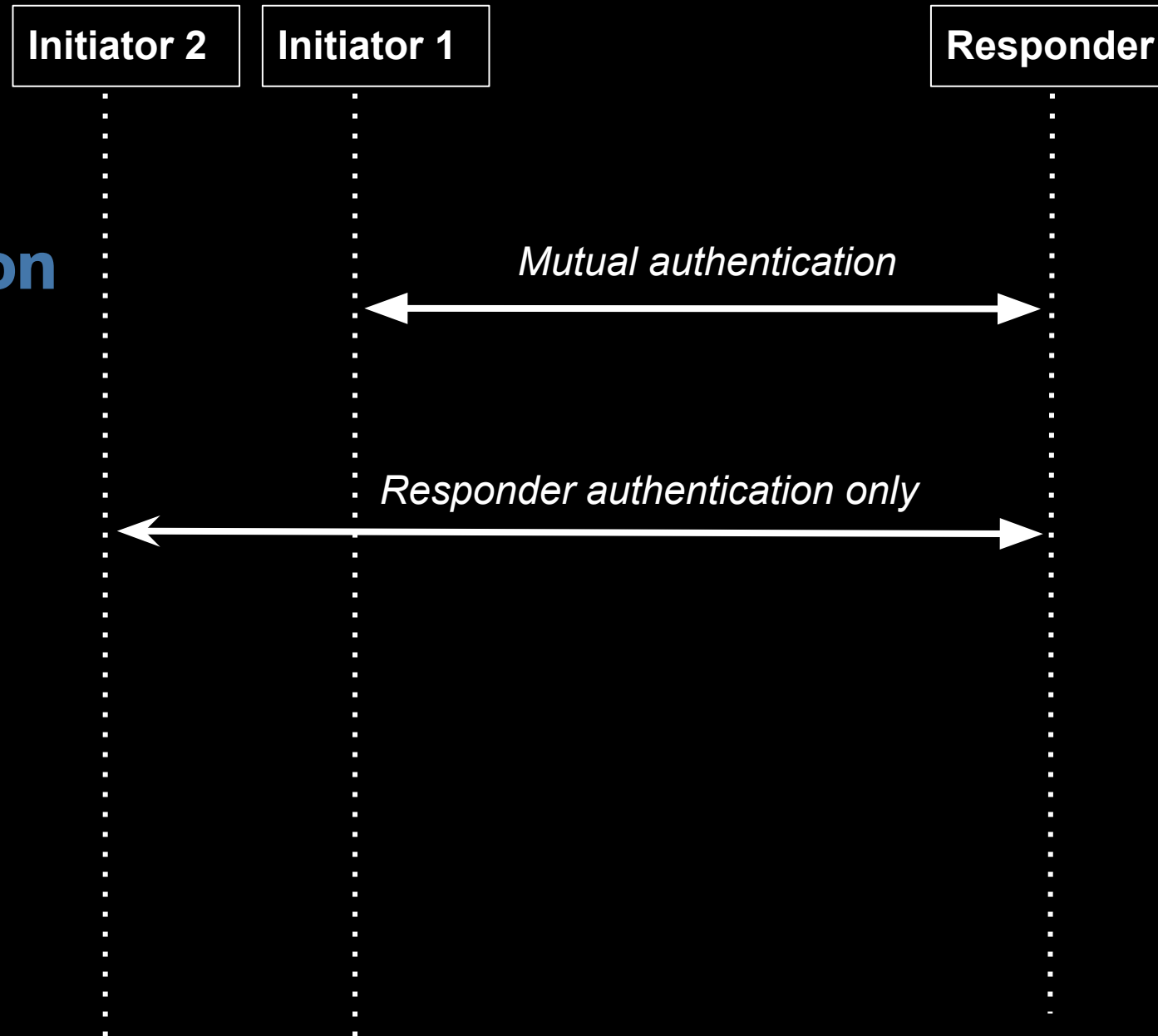
# DPP Mixed Authentication

- Not all devices implement the full DPP spec — some support only limited provisioning methods (e.g., QR code only).
- Network operators may enable multiple provisioning options (e.g., QR code and PKEX) to support diverse device capabilities
- Some provisioning methods skip mutual auth
- Result: Mixed authentication modes co-exist within the same network.

## DPP Mixed Authentication



## DPP Mixed Authentication



# QR Code Authentication Mode

- QR code provisioning uses single-factor auth—unlike PKEX, BLE, or NFC, which support mutual auth
- Initiator authenticates the Responder by scanning its public key—but the Responder never fully authenticates the Initiator
- Trust is implicitly granted just because the Initiator holds the public key—no identity verification occurs in return
- If an attacker locates the QR code (i.e., the public key), they can bypass the stronger auth expected in methods like PKEX



# Locating Static QR Codes via DPP Auth Request Sniffing

- DPP Authentication Requests contain the bootstrapping key hash, linking them to a specific QR code used during provisioning.
- If a static QR code (e.g., printed on a wall) is used repeatedly, the same hash will be observed in multiple Auth Requests over time.
- By passively capturing these frames across different monitoring points, triangulation techniques can estimate the QR code's physical location.

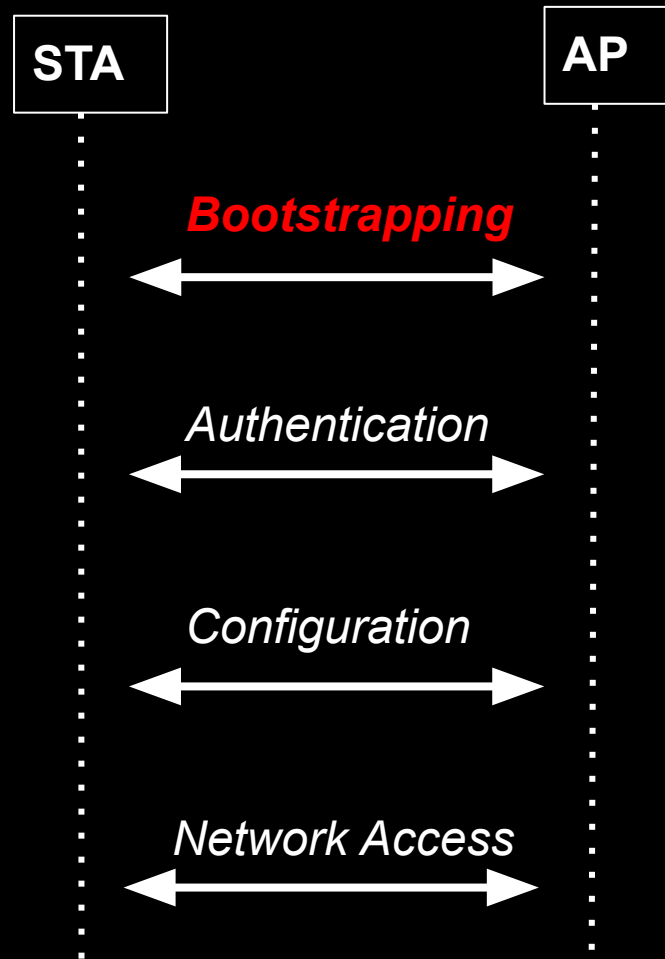
# Wi-Fi Alliance Response

“[The DPP protocol]... is not required to perform non-mutual in the event that mutual is not available. This is a policy decision for the deployed Enrollee”

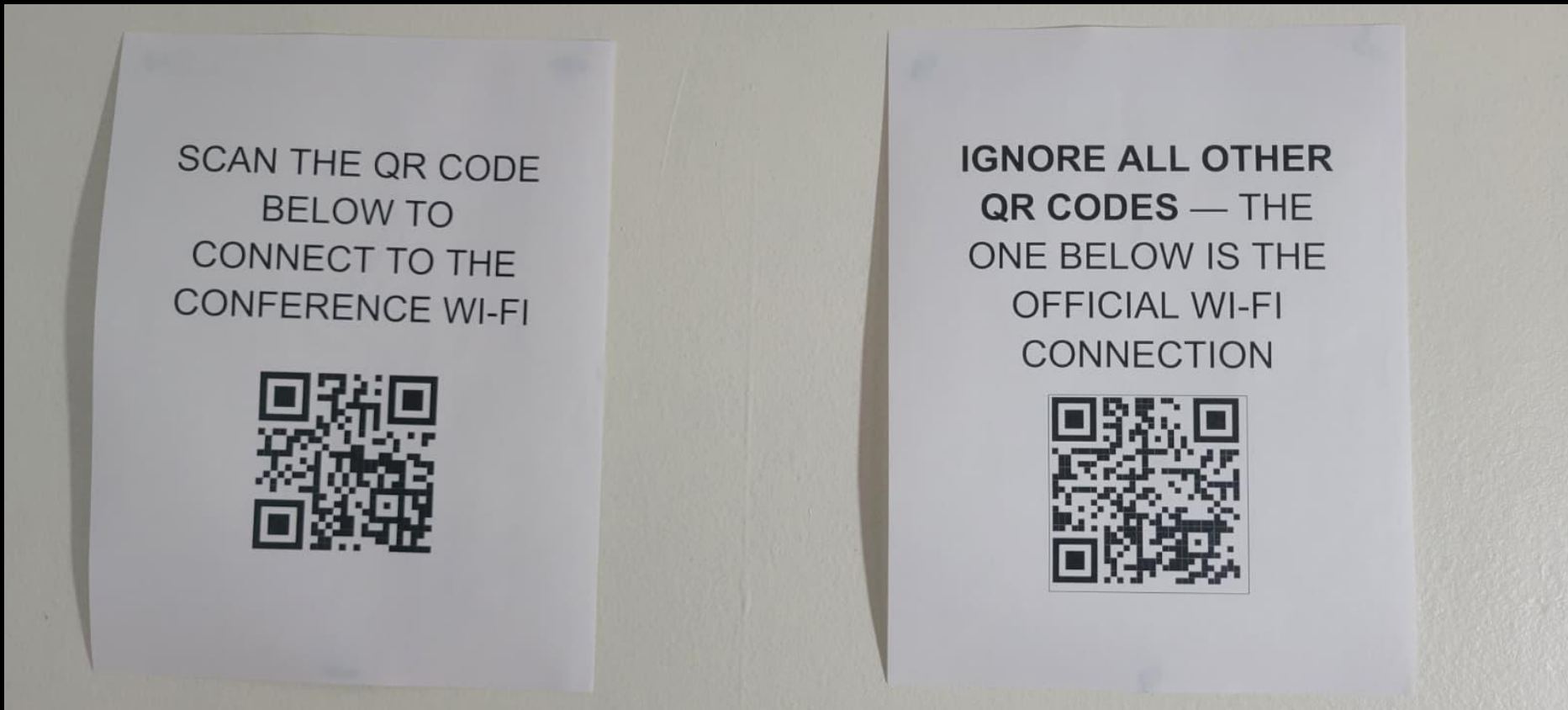
# Proposed Remediation

- The Wi-Fi Alliance likely intended mixed auth modes for flexibility — but flexibility can backfire
- Wi-Fi environments are inherently hostile: spoofing, sniffing, and downgrades are trivial
- Many operators lack the expertise to properly manage multi-method auth setups
- Protocol should not allow mixing weak and strong auth — it creates silent downgrade paths
- If mutual authentication is enabled, all connections should be forced to use it — no exceptions
- A strict “mutual-auth only” mode would ensure the Responder always verifies the Initiator
- Some DPP implementations may enforce this already — but unless it’s baked into the spec, it’s not guaranteed





# QR Code Evil Twin



# PKEX Code Reuse Exploitation

- hostapd & PKEX Reuse (CVE-2022-37660)
- PKEX codes (a.k.a. passwords) were not deleted after successful pairing—against spec requirements.
- Public key regenerated each time, but same code stays alive = replay & impersonation possible.
- Exploit path: Attacker reuses the same code to masquerade as a legit Responder and hijack new clients.

# PKEX Code Re-use

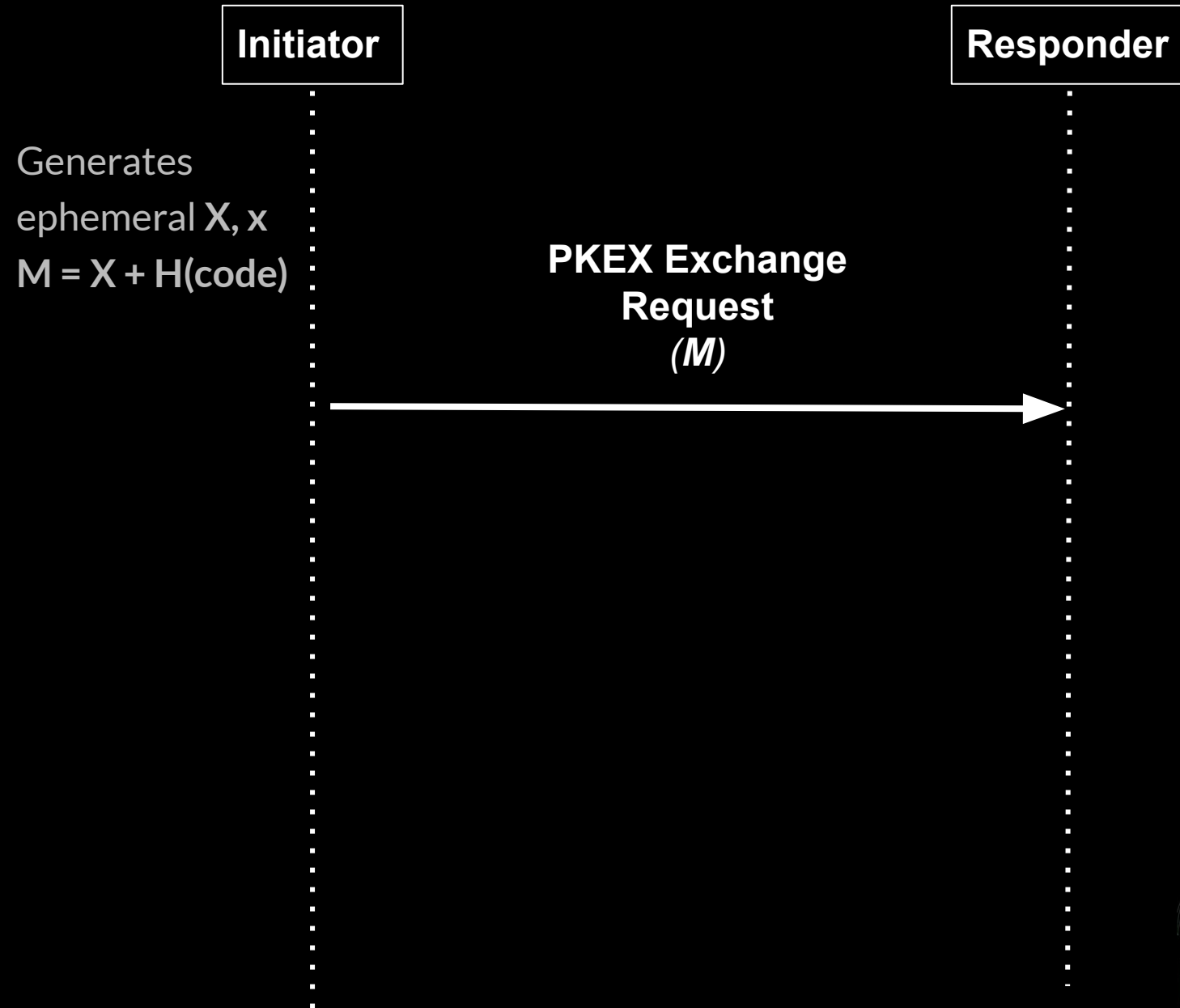
Initiator

Generates  
ephemeral  $X, x$   
 $M = X + H(\text{code})$

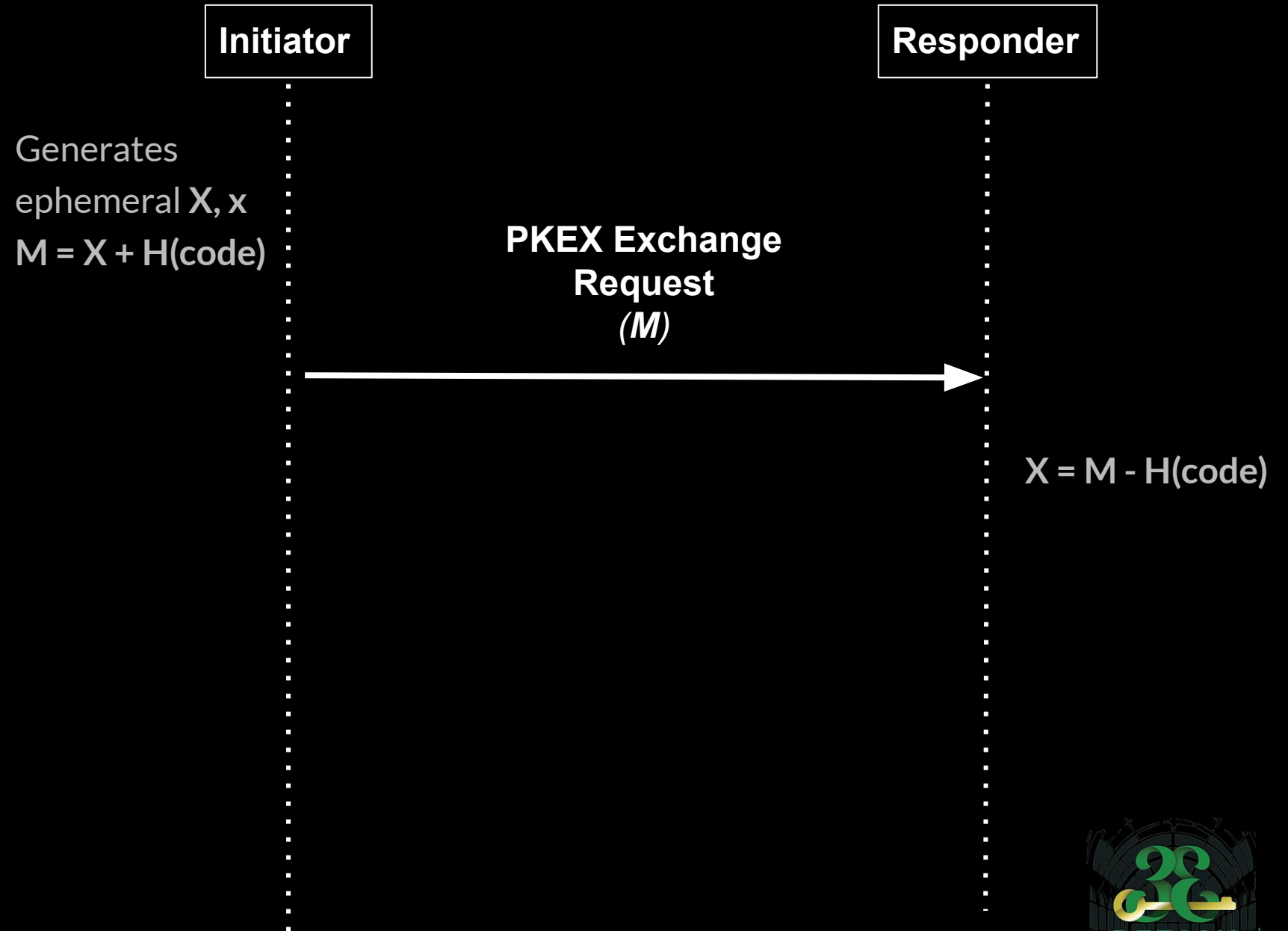
Responder



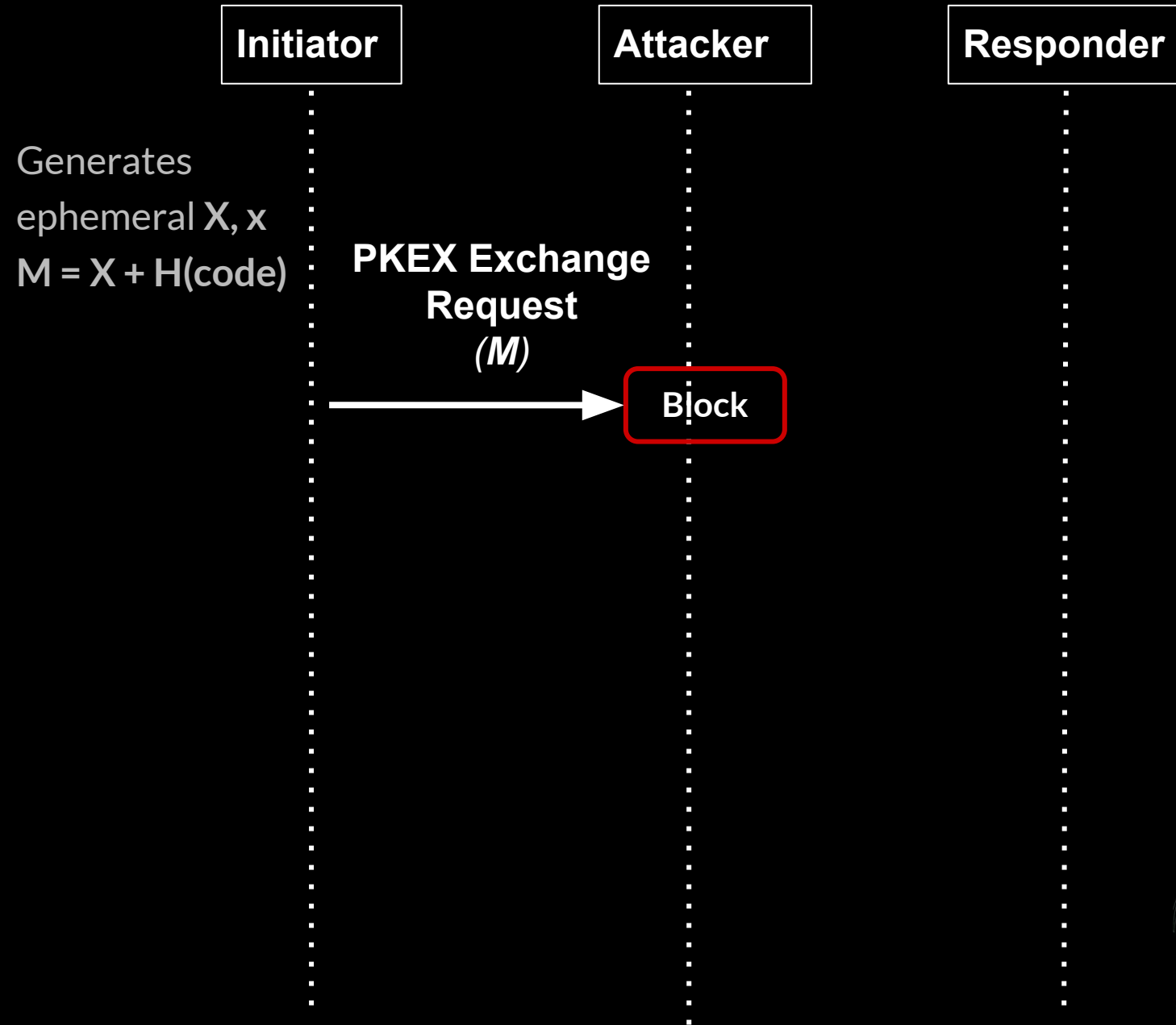
## PKEX Code Re-use



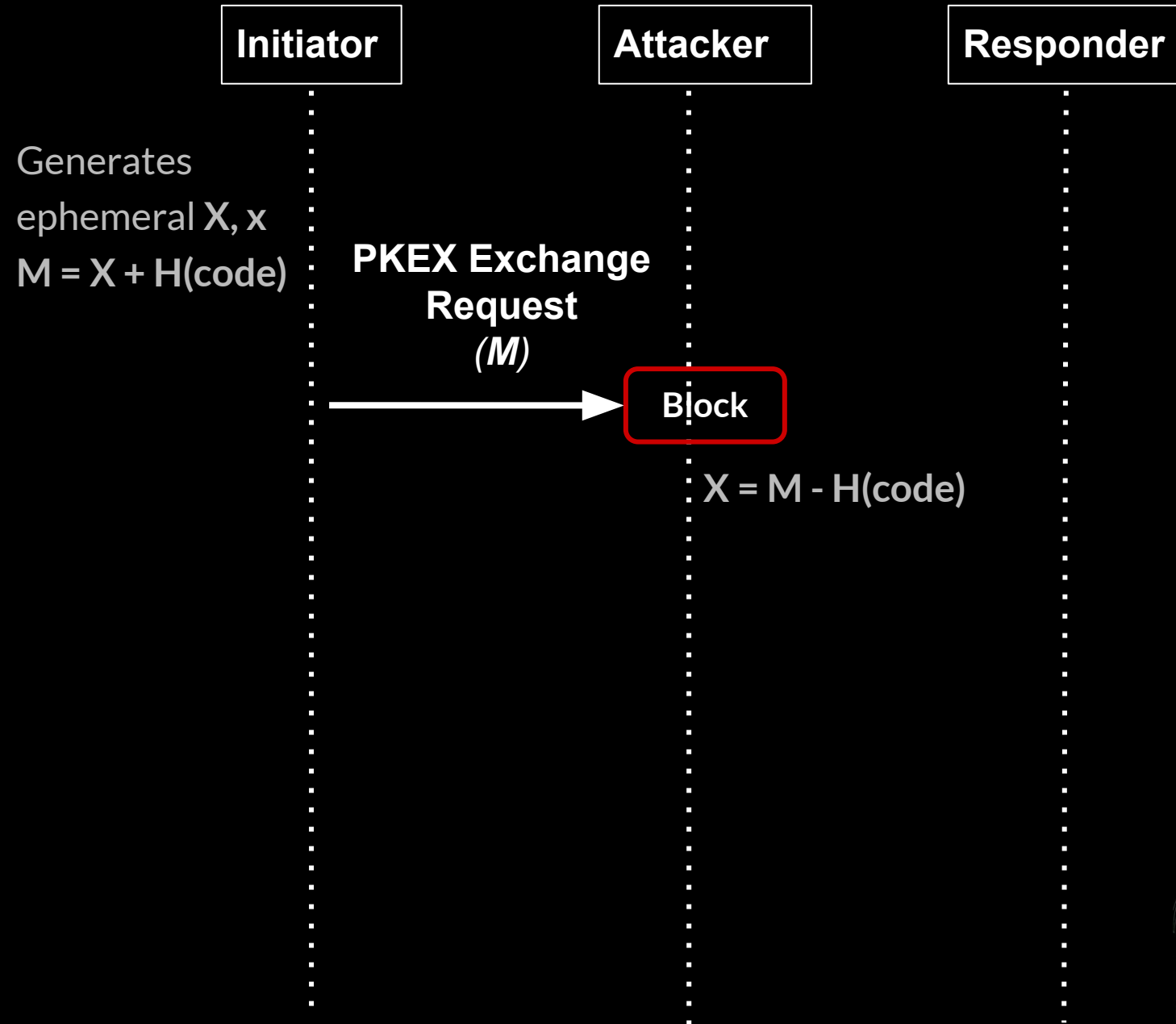
## PKEX Code Re-use



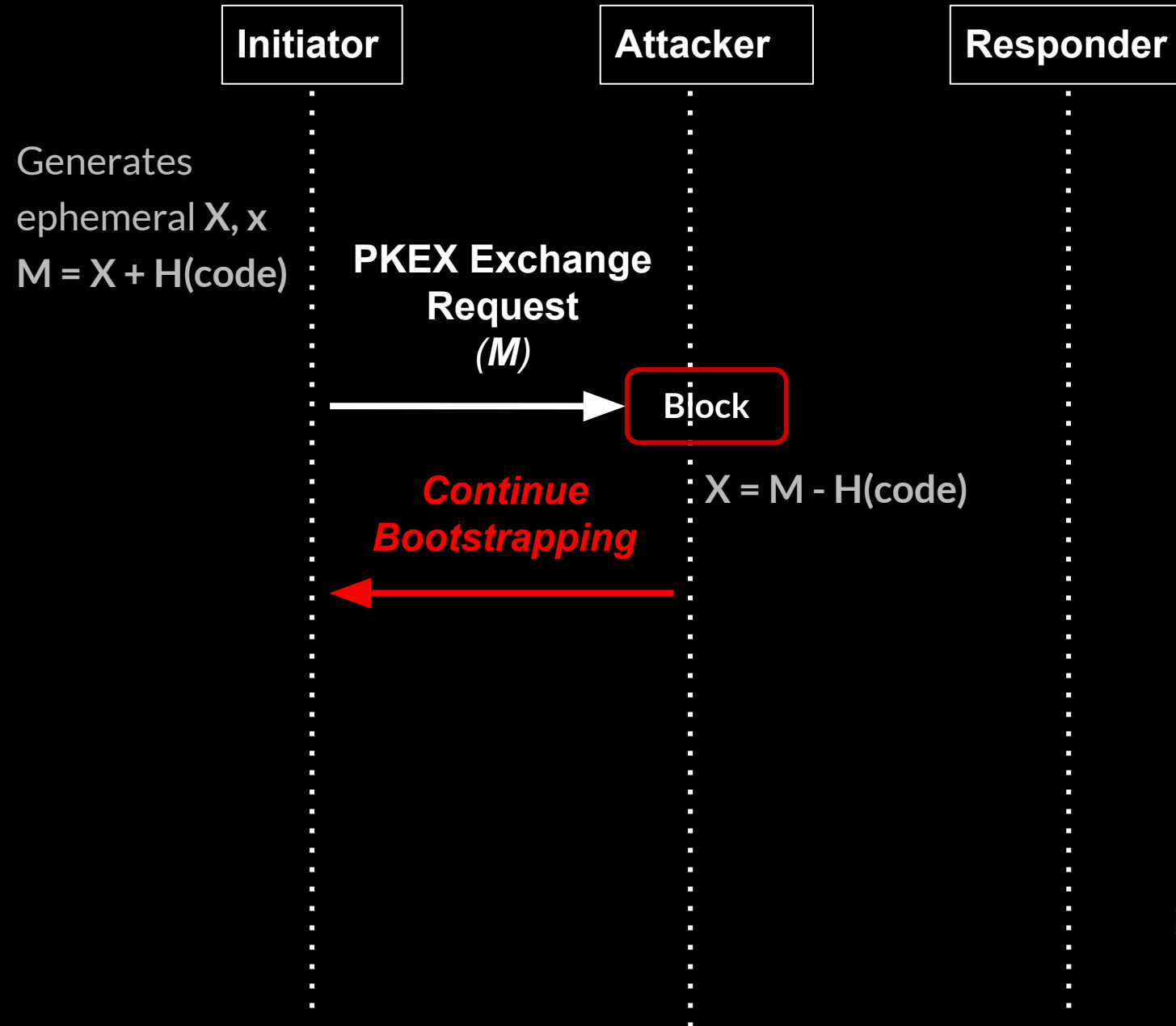
## PKEX Code Re-use



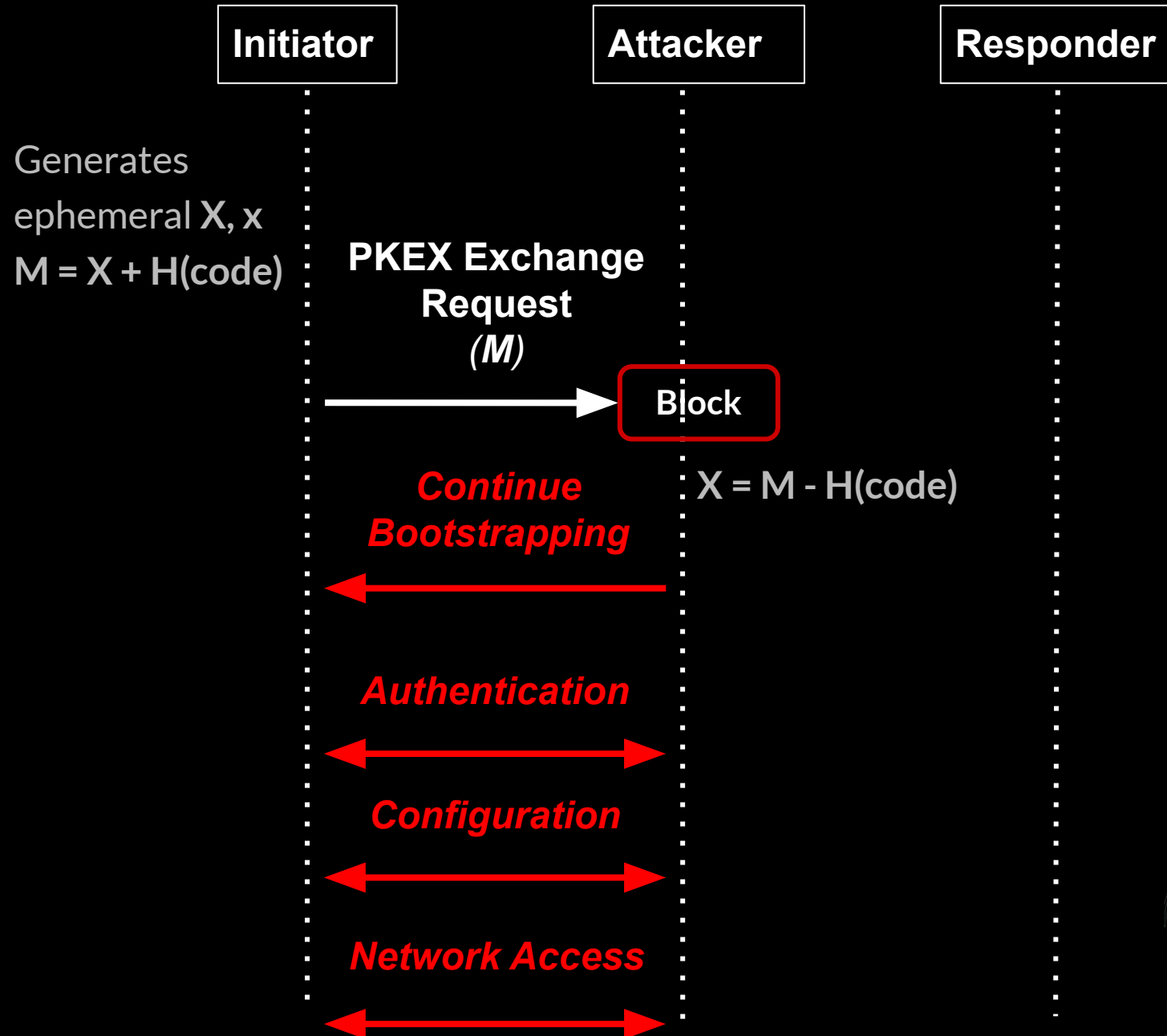
## PKEX Code Re-use

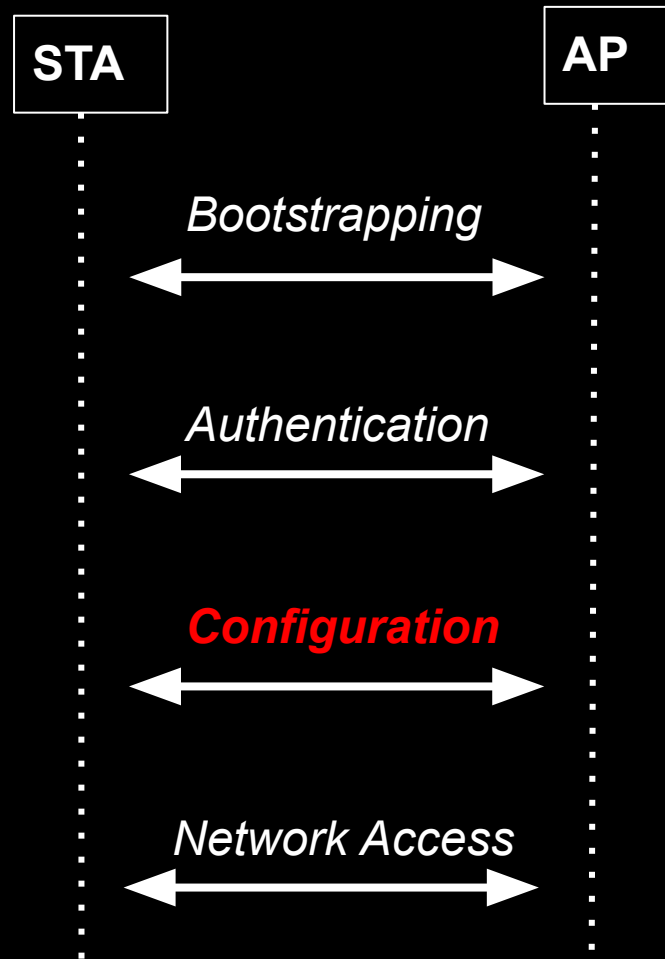


## PKEX Code Re-use

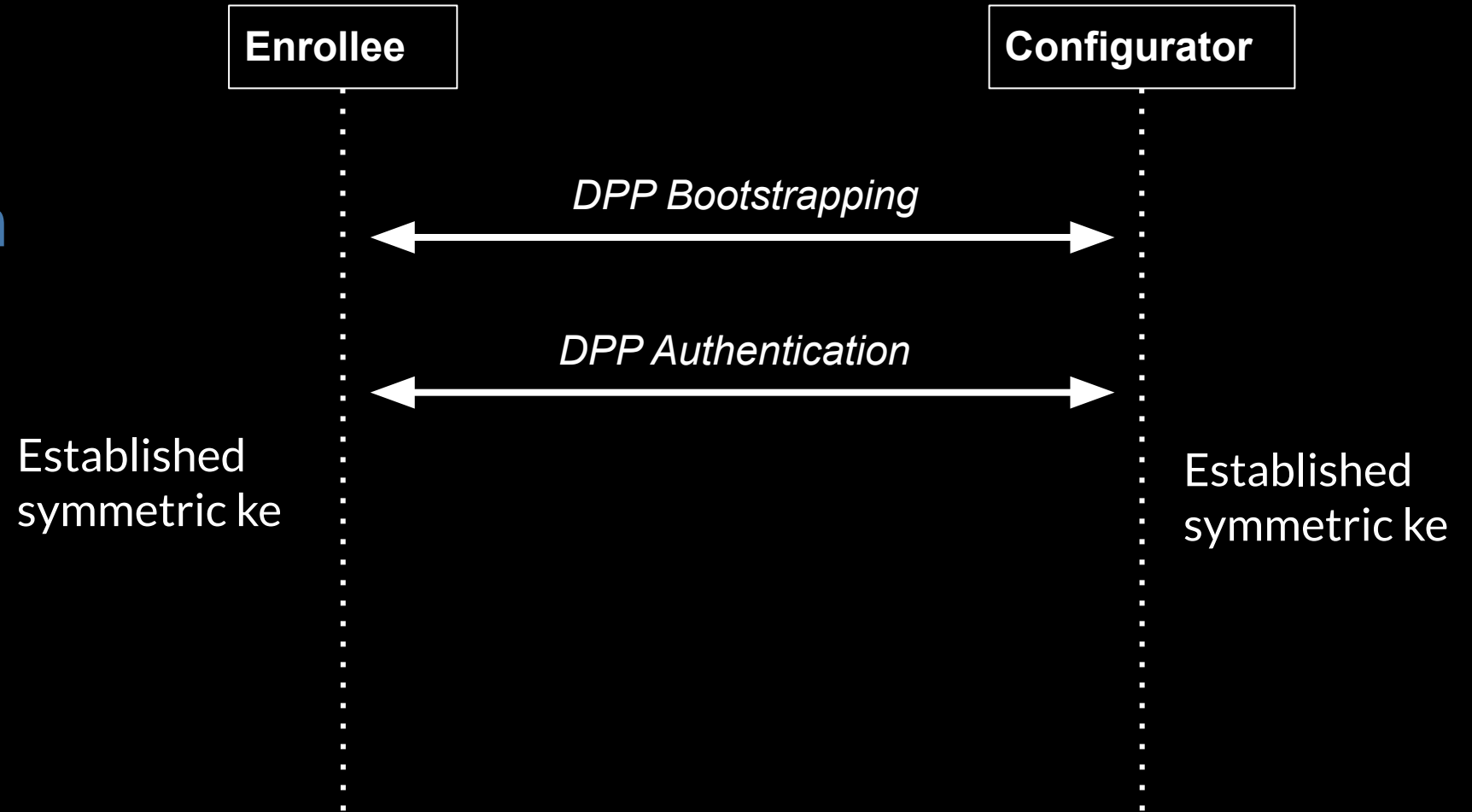


# PKEX Code Re-use



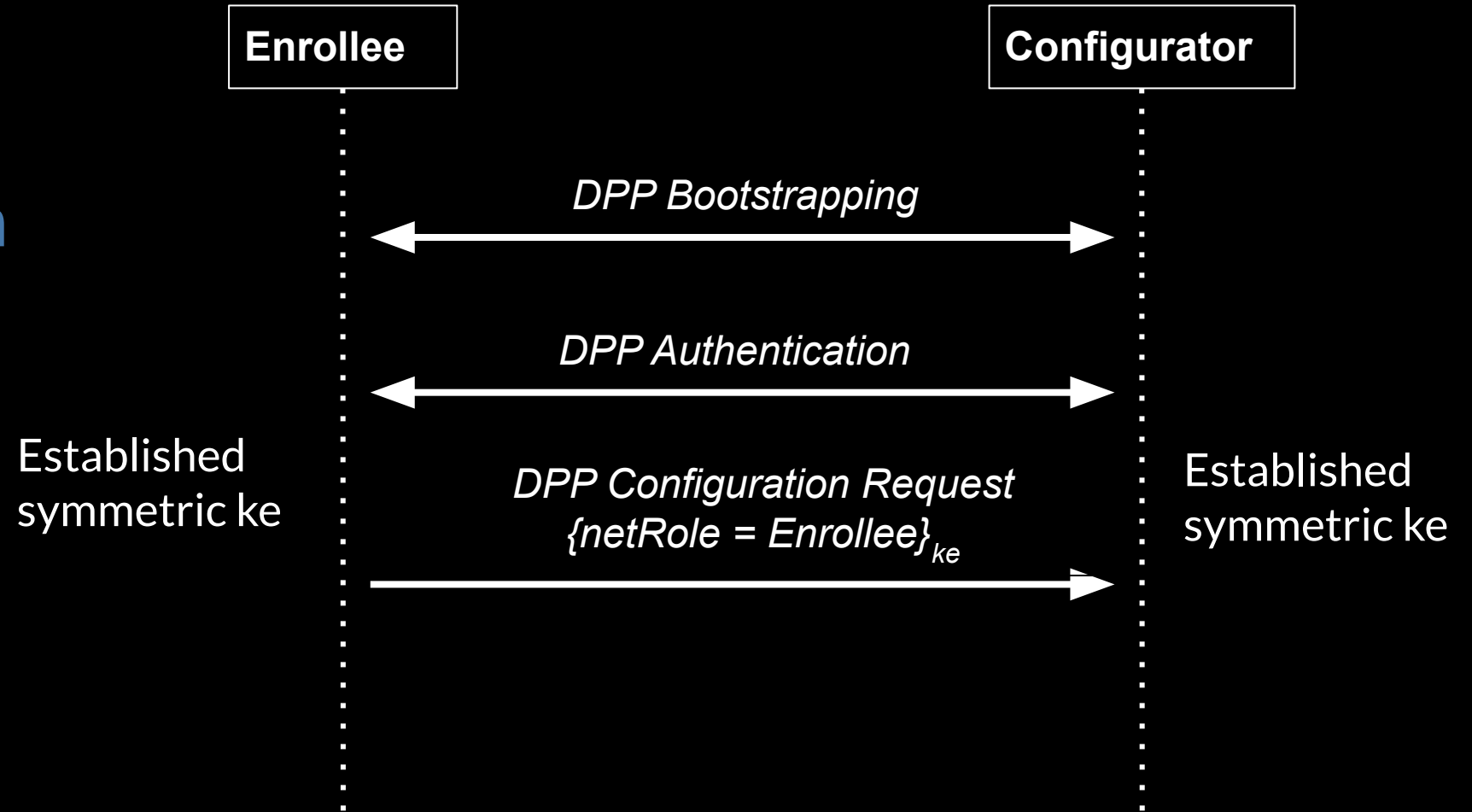


# DPP Configuration

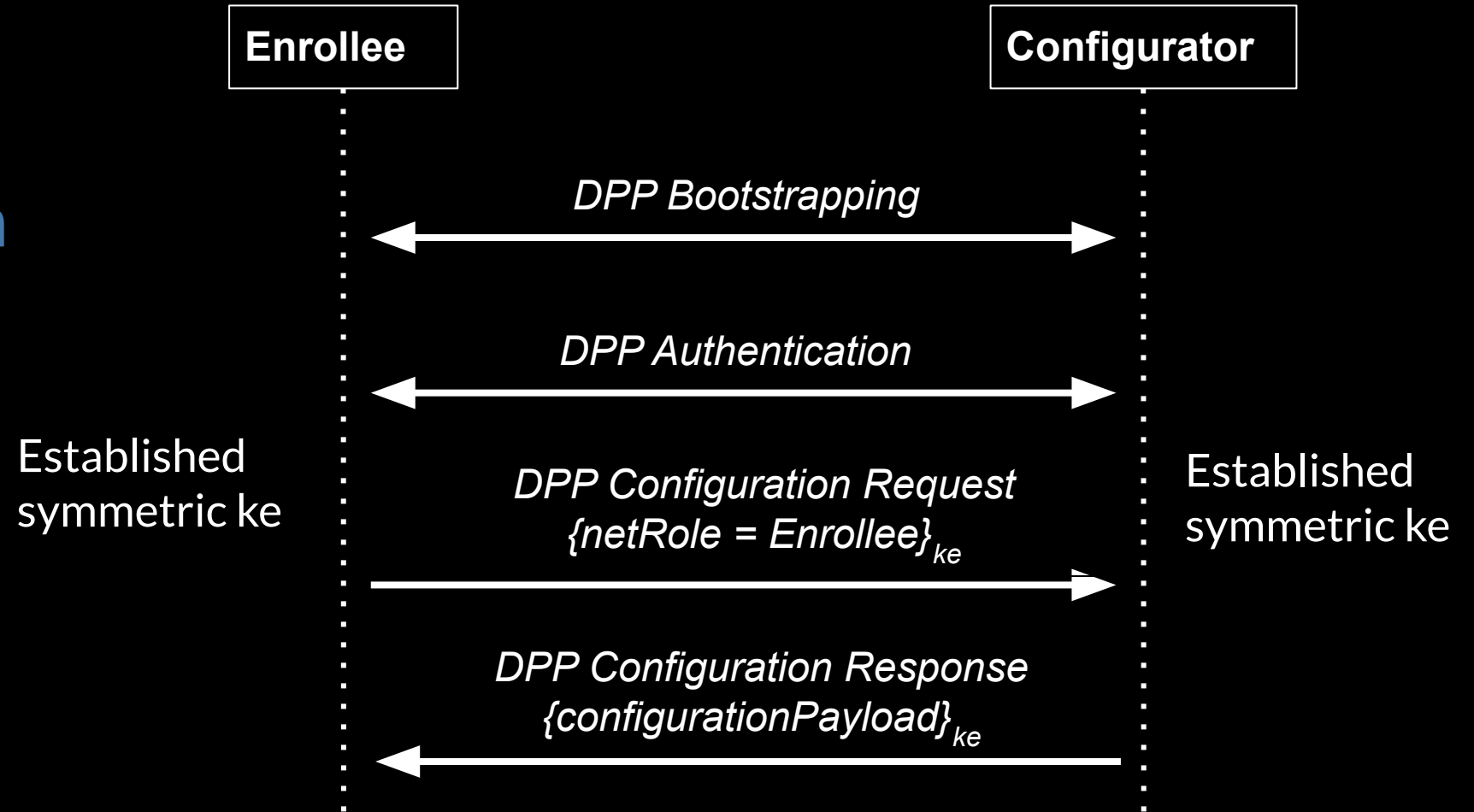




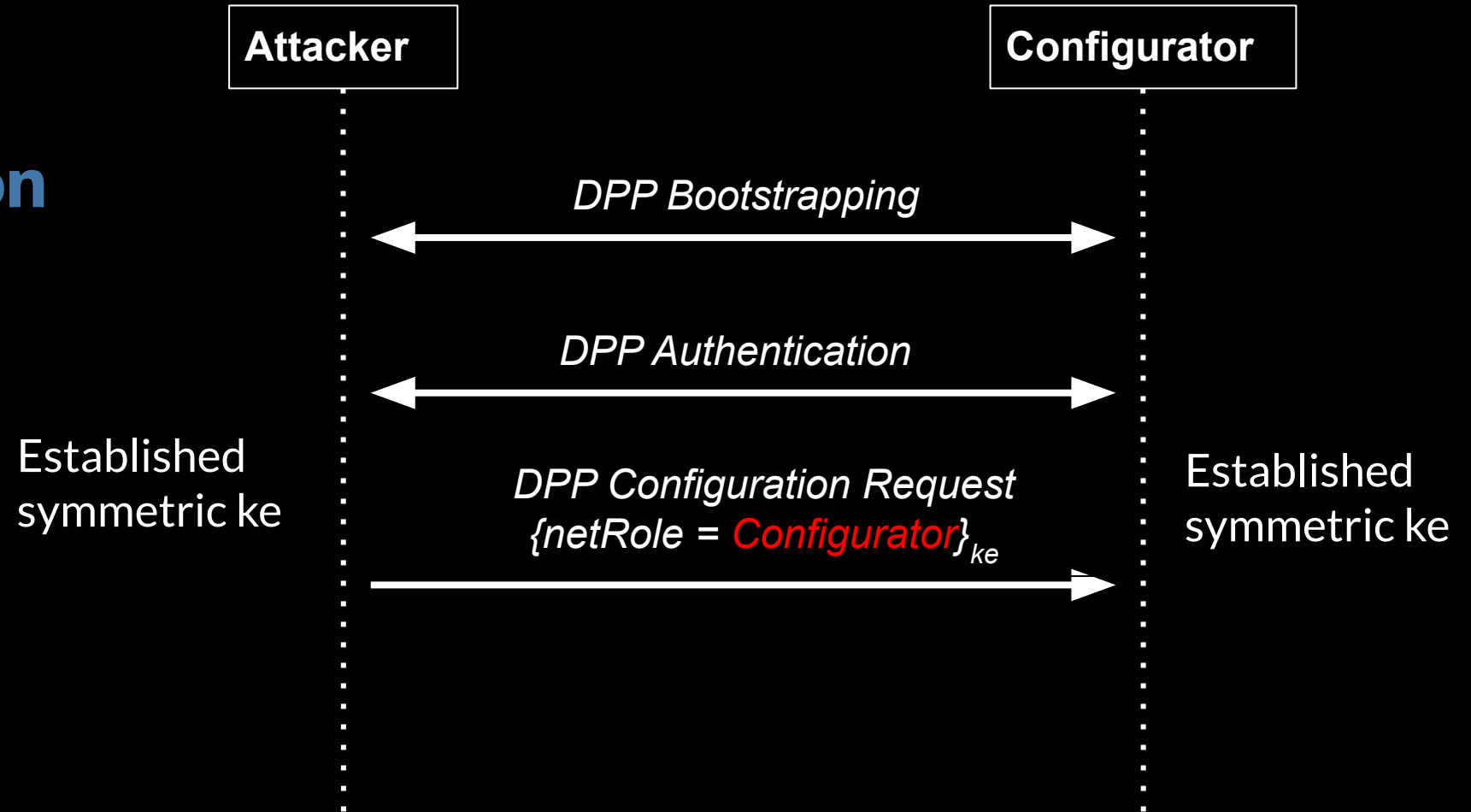
# DPP Configuration



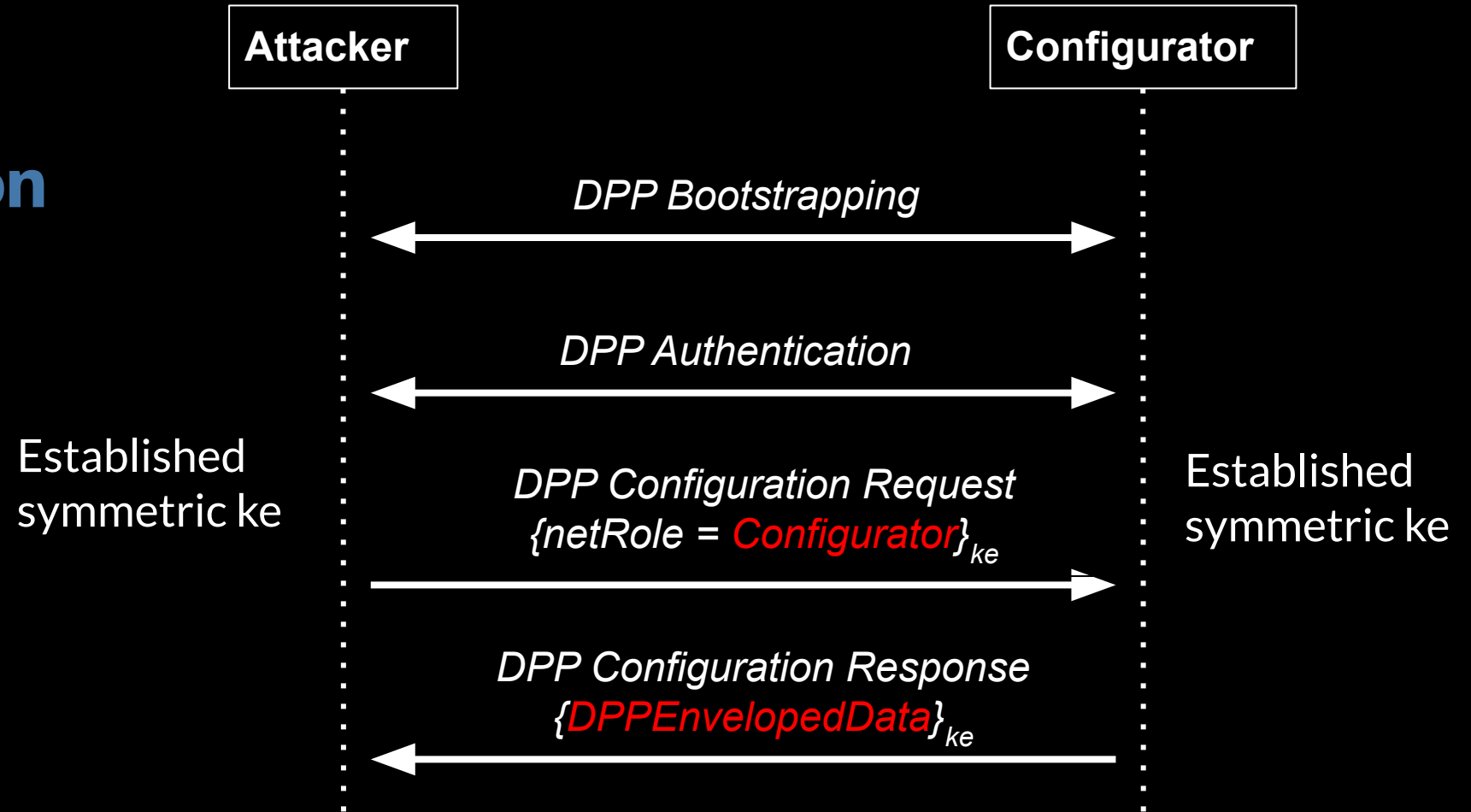
# DPP Configuration



# Configurator Impersonation Attack

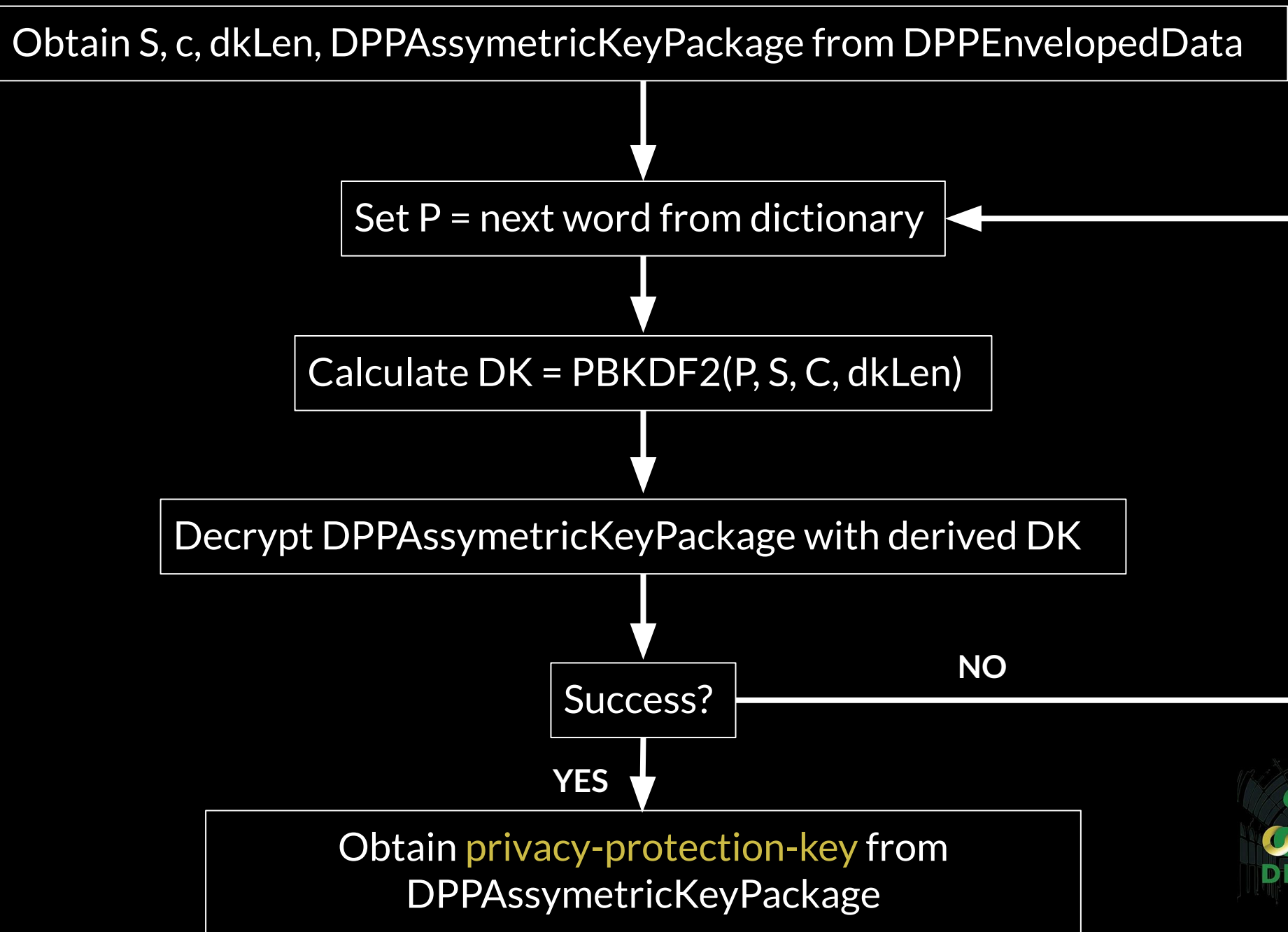


# Configurator Impersonation Attack



# DPP Enveloped Data

- A container format for securely backing up and restoring Configurator credentials
- Used to enable multiple Configurators in a DPP network
- Management of the storage location and its security is completely vendor-specific
- Password-derived key encryption — crack the password, decrypt the envelope, own the network



# One Key to Own Them All

- Privacy Protection Key (PPK) key is shared across all Configurators—past, present, and compromised
- With PPK in hand, attacker can sign and distribute rogue network configs
- Rogue configs = full control: impersonate APs, redirect traffic, MITM all clients
- One bad Configurator = global compromise of the Wi-Fi Easy Connect network

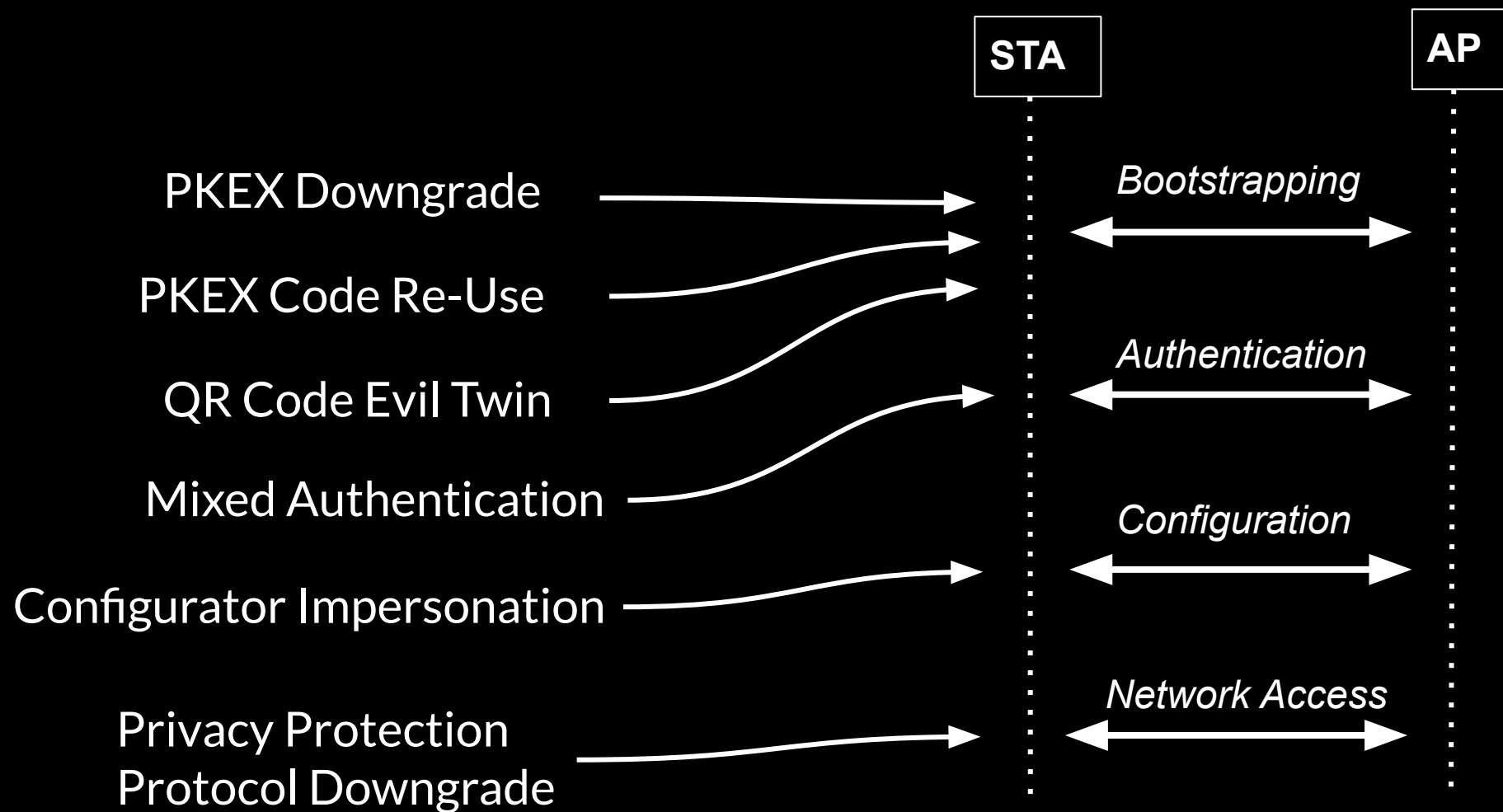
## Wi-Fi Alliance Response

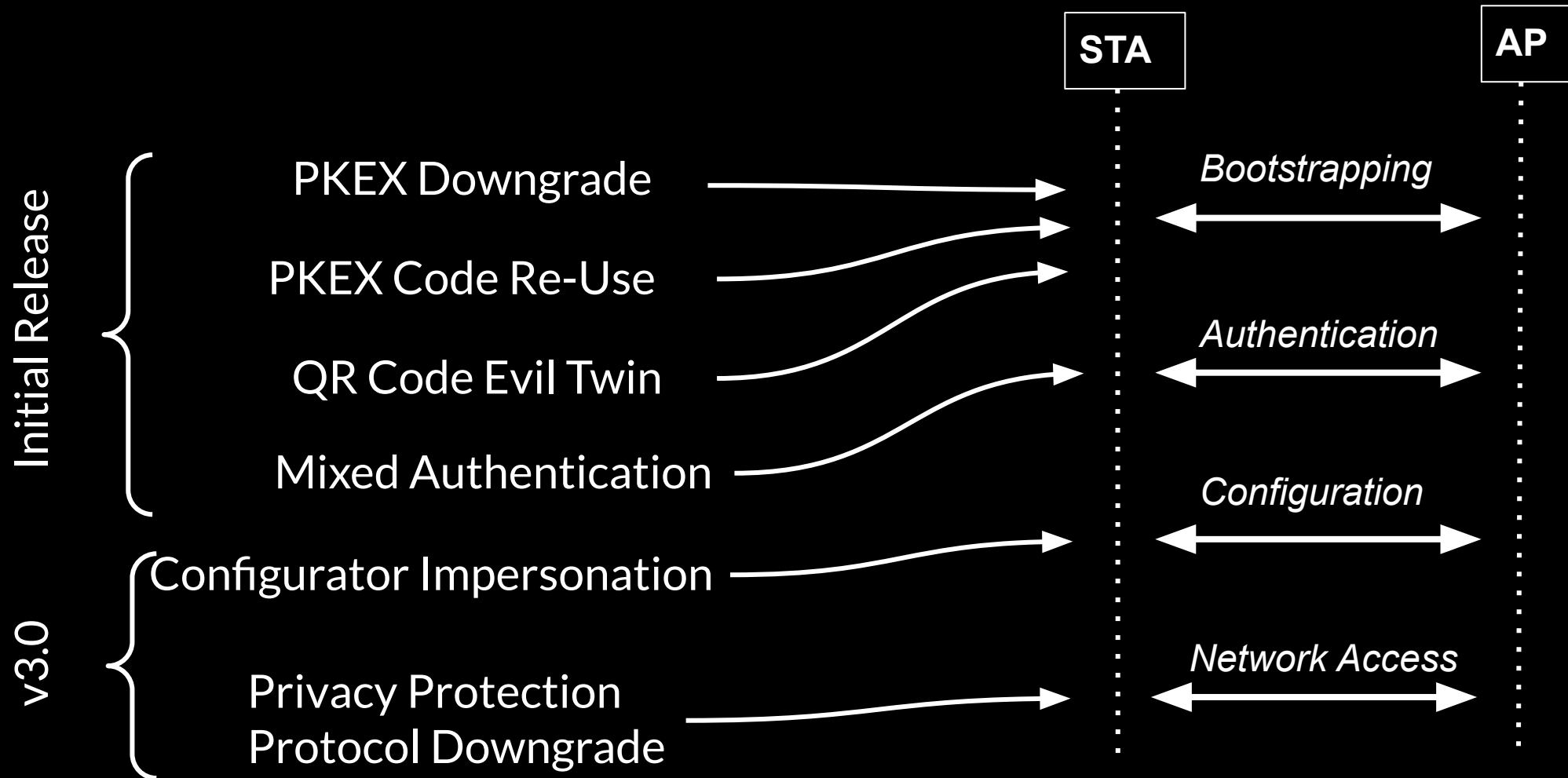
“Wi-Fi Alliance will consider allowing for other methods of protecting the DPPEncryptedData, in addition to the password method which is considered an acceptable risk.”



# Proposed Remediation

- Wi-Fi Alliance's current fix is insufficient — password-based method still exploitable, and DPPEncryptedData remains at risk.
- **Fix #1** – Authorization Checks:
  - Enforce authorization logic before granting Configurator status.
  - Validate Enrollee identity against policy-based controls.
  - Prevent rogue Configurator promotion attempts.
- **Fix #2** – Per-Configurator Keys:
  - Assign a unique cryptographic key to each Configurator.
  - Eliminates shared-key risk. Breach of one ≠ breach of all.





# Conclusions

- Several protocol-level vulnerabilities are inherent to the DPP design — mitigation requires spec updates
- Migration from WPS to DPP shifts risk to network operators, demanding security-savvy deployment
- Usability-driven enhancements (v2/v3) have weakened the protocol's security posture
- Features like mixed auth modes and Configurator impersonation open new vectors for abuse
- Lack of revocation mechanisms for critical keys leads to persistent compromise risk
- Protocol adoption must be matched with operator education and clear provisioning policies

# Breaking WiFi Easy Connect

## A security Analysis of DPP

George Chatzisoifroniou (@\_sophron)



# DEF CON 33

August 7-10, 2025 | Las Vegas

Presented research has been peer-reviewed and published in:

Chatzisoifroniou, G., Kotzanikolaou, P. Security analysis of the Wi-Fi Easy Connect. *Int. J. Inf. Secur.* 24, 74 (2025). <https://doi.org/10.1007/s10207-025-00988-3>

# References

- Chatzisoifroniou, G., Kotzanikolaou, P. Security analysis of the Wi-Fi Easy Connect. Int. J. Inf. Secur. 24, 74 (2025). <https://doi.org/10.1007/s10207-025-00988-3>
- Wi-Fi Alliance. Wi-Fi Protected Setup (WPS) Specification version 1.0h. 2006. link (2015)
- Viehbck, S.: Wi-Fi Protected Setup online pin brute force vulnerability (2011)
- Wi-Fi Alliance. Device provisioning protocol (dpp) specification, Technical Specification, Wi-Fi Alliance, Latest Version. link (2025). Accessed 02 Jan 2025
- Wi-Fi Alliance. Wi-Fi Alliance product finder. link. Accessed 07 Jan 2023
- Group, N.: Ble proximity authentication vulnerable to relay attacks. Available: link (2023). Accessed 02 Jan 2025
- Nobles, P.: Vulnerability of IEEE802.11 WLANs to MAC layer DoS attacks. In: IET Conference Proceedings, pp. 14–14(1). link (2004)
- Bernstein D.J., Hamburg, M., Krasnova, A., Lange, T.: Elligator: elliptic-curve points indistinguishable from uniform random strings. In: Proceedings of the 2013 ACM SIGSAC conference on Computer & Communications Security, pp. 967–980 (2013)
- WiFi Alliance: WPA3 specification version 1.0. Available: link
- Vanhoef, M., Ronen, E.: Dragonblood: analyzing the dragonfly handshake of WPA3 and EAP-pwd. In: IEEE Symposium on Security & Privacy (SP). IEEE (2020)
- Chatzisoifroniou, G., Kotzanikolaou, P.: Association attacks in IEEE 802.11: exploiting WiFi usability features. In: Proceedings of the International Workshop on Socio-Technical Aspects in Security and Trust (STAST). Springer, pp. 107–123 (2019)
- National Institute of Standards and Technology (NIST): A closer look at revocation and key compromise in public key infrastructures. National Institute of Standards and Technology, Tech. Rep. link (2023). Accessed 02 Jan 2025
- IEEE Standard for Local and Metropolitan Area Networks–PortBased Network Access Control, IEEE Std. 802.1X-2010. link (2010)
- Common Vulnerability and Exposure database: CVE-2022-37660. link (2022)
- Rondon, L.P., Babun, L., Aris, A., Akkaya, K., Uluagac, A.S.: Survey on enterprise internet-of-things systems (e-iot): a security perspective. Ad Hoc Networks, vol. 125, p. 102728. link (2022)
- Vanhoef, M., Piessens, F.: Key reinstallation attacks: Forcing nonce reuse in wpa2. In: Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, ser. CCS '17. ACM, New York, NY, USA, pp. 1313–1328. link (2017)
- Vanhoef, M.: A time-memory trade-off attack on wpa3's sae-pk. In: Proceedings of the 9th ACM on ASIA Public-Key Cryptography Workshop, ser. APKC '22, pp. 27–37. Association for Computing Machinery, New York, NY. link (2022)
- Marais, S., Coetzee, M., Blauw, F.: Simultaneous deauthentication of equals attack. In: Wang, G., Chen, B., Li, W., Di Pietro, R., Yan, X., Han, H. (eds.) Security, Privacy, and Anonymity in Computation, Communication, and Storage, pp. 545–556. Springer, Cham (2021)
- Kampourakis, V., Chatzoglou, E., Kambourakis, G., Dolmes, A., Zaroliagis, C.: Wpaxfuzz: sniffing out vulnerabilities in wi-fi implementations. In: Cryptography, vol. 6, no. 4. link (2022)
- Chatzoglou, E., Kambourakis, G., Kolias, C.: How is your WiFi connection today? DoS attacks on WPA3-SAE. J. Inf. Secur. Appl. 64, 103058 (2022)
- Chatzisoifroniou, G., Kotzanikolaou, P.: Exploiting WiFi usability features for association attacks in IEEE 802.11: attack analysis and mitigation cont